Note - Penetration Testing

Jonathan Colombo

26 ottobre 2026

Indice

1 Introduzione all'Ethical Hacking **8**
1.1 Concetti Fondamentali 8
1.1.1 Introduzione all'Ethical Hacking 8
1.2 Fasi di un Attacco di Rete 9
1.2.1 Sequenza Generale 9
1.2.2 Metodologia Professionale del Penetration Testing 9
1.3 Considerazioni Metodologiche 9

2 Il Modello ISO/OSI **10**
2.1 Introduzione 10
2.2 I Sette Livelli del Modello 10
2.2.1 1. Physical Layer (Livello Fisico) 10
2.2.2 2. Data Link Layer (Livello di Collegamento Dati) 10
2.2.3 3. Network Layer (Livello di Rete) 10
2.2.4 4. Transport Layer (Livello di Trasporto) 11
2.2.5 5. Session Layer (Livello di Sessione) 11
2.2.6 6. Presentation Layer (Livello di Presentazione) 11
2.2.7 7. Application Layer (Livello di Applicazione) 11
2.3 Nota Operativa per il Penetration Testing 11

3 L'Indirizzo MAC (Media Access Control) **12**
3.1 Introduzione 12
3.2 1. Livello di Funzionamento e Ambito Locale 12
3.3 2. Ruolo dello Switch e i Frame Ethernet 12
3.4 3. Transizione da MAC a IP: Il Protocollo ARP 13
3.5 4. Come Visualizzare l'Indirizzo MAC 13
3.6 Nota Operativa 13

4 L'Indirizzo IP (Internet Protocol) **13**
4.1 Introduzione 13
4.2 1. Struttura dell'Indirizzo IPv4 14
4.2.1 Classi di Indirizzi Classful 14
4.2.2 Subnetting e Notazione CIDR 14

4.3 2. Indirizzi IP Pubblici e Privati 14
4.4 3. Meccanismi di Rete Essenziali 15
4.4.1 NAT (Network Address Translation) 15
4.4.2 Default Gateway 15
4.4.3 DHCP (Dynamic Host Configuration Protocol) 15
4.4.4 DNS (Domain Name System) 15
4.5 4. Comandi Utili per l'Amministrazione degli IP 15
4.6 5. IPv6: L'Evoluzione 16

5 Il Protocollo ARP (Address Resolution Protocol) 16
5.1 Introduzione 16
5.2 1. Ruolo e Posizionamento nella Pila ISO/OSI 16
5.3 2. Meccanismo di Funzionamento 17
5.4 3. Gestione e Visualizzazione della Tabella ARP 17
5.5 4. ARP nel Troubleshooting di Rete 17
5.6 5. ARP nel Network Scanning 18
5.7 Nota Operativa 18

6 Il Default Gateway 18
6.1 Funzione e Utilità 18
6.2 Esempio Pratico e Configurazione 19
6.3 Come Individuare il Default Gateway 19

7 Il Network Address Translation (NAT) 19
7.1 Perché è necessario il NAT 19
7.2 Funzionamento della Traduzione: Un Esempio 20
7.3 Condivisione dell'IP Pubblico e Port Mapping 20
7.4 Vantaggi Principali del NAT 20

8 Il Domain Name System (DNS) 20
8.1 Struttura Gerarchica del DNS 21
8.2 DNS Pubblici e DNS Privati 21
8.3 Protocolli e Porte 21
8.4 Strumenti di Interrogazione DNS 21
8.5 Trasferimento di Zona (DNS Zone Transfer) e Sicurezza 22

9 Il Protocollo DHCP (Dynamic Host Configuration Protocol) 22
9.1 Motivazioni e Obiettivi 22
9.2 Porte e Protocollo di Trasporto 23
9.3 La Sequenza DORA 23
9.3.1 DHCPDISCOVER (Scoperta) 23
9.3.2 DHCPOFFER (Offerta) 23
9.3.3 DHCPREQUEST (Richiesta) 24
9.3.4 DHCPACK (Conferma) 24
9.4 Comandi Utili e Diagnostica 24
9.4.1 Configurazione DHCP su Windows 24

9.4.2 Log DHCP su Linux/Unix 24

10 Porte e Servizi nelle Reti: Concetti Fondamentali per l'Ethical Hacking 24
10.1 Classificazione delle Porte 24
10.2 Servizi e Porte Standard 25
10.2.1 Navigazione Web e Trasferimento File 25
10.2.2 Accesso Remoto e Amministrazione 25
10.2.3 Servizi Infrastrutturali di Rete 25
10.2.4 Posta Elettronica 25
10.2.5 Condivisione Risorse e Directory (Windows/Samba) . . . 26
10.2.6 Database Relazionali 26
10.3 Sistemi Industriali (ICS/SCADA) 26
10.4 Firewall, NAT e Port Forwarding 26

11 Diagnostica e Troubleshooting di Rete secondo il Modello ISO-OSI 26
11.1 1. Verifica Fisica (Physical Layer) 27
11.2 2. Verifica dell'Indirizzo IP (Network Layer) 27
11.3 3. Test di Raggiungibilità: PING (Network Layer) 27
11.4 4. Analisi ARP (Data Link Layer) 27
11.5 5. Traceroute 27

12 GNS3: Simulazione ed Emulazione di Reti Informatiche 28
12.1 1. Emulazione di Dispositivi e Topologie di Rete 28
12.2 2. Integrazione con la Virtualizzazione 28
12.3 3. Analisi del Traffico con Wireshark 28
12.4 4. Gestione delle Risorse 28

13 Segmentazione della Rete: LAN, WAN e DMZ 29
13.1 1. LAN (Local Area Network) 29
13.2 2. WAN (Wide Area Network) 29
13.3 3. DMZ (Demilitarized Zone) 29
13.4 Politiche di Flusso sul Firewall Perimetrale 29

14 Lo Switch: Funzionamento, Struttura e Ruolo nella LAN 30
14.1 1. Ruolo e Ambito di Funzionamento 30
14.2 2. Elaborazione dei Frame Ethernet 30
14.3 3. La Tabella CAM (Content Addressable Memory) 30
14.4 4. Algoritmo di Smistamento del Traffico 30
14.5 5. Funzionalità Avanzate e Sicurezza 31

15 Il Router: Funzioni, Struttura e Ruolo nel Network Layer 31
15.1 1. Funzione Principale e Livello ISO-OSI 31
15.2 2. Collegamento tra Sottoreti Diverse 31
15.3 3. Connessione a Internet e Default Gateway 31
15.4 4. Servizi e Funzionalità Integrate 32

15.5 5. Sicurezza e Simulazione 32

16 Il Firewall: Struttura, Funzionamento e Ruolo nella Sicurezza di Rete 32
16.1 1. Posizionamento e Livello ISO-OSI 32
16.2 2. Filtraggio dei Pacchetti e Criteri delle Regole 33
16.3 3. Ordine delle Regole, Cleanup Rule e Default Deny 33
16.4 4. Tipologie e Soluzioni di Mercato 33
16.5 5. Fasi di Configurazione Standard 33
16.6 6. Impatto nel Penetration Testing 34

17 Fortinet e pfSense: Soluzioni Firewall Enterprise e Open Source 34
17.1 Fortinet Firewall 34
17.1.1 Fasi di Configurazione Base 34
17.1.2 Criteri di Filtraggio e Gestione delle Regole 34
17.2 pfSense 35

18 M4 Lab: Progettazione e Gestione del Laboratorio Virtuale di Pentesting 35
18.1 1. Introduzione al Laboratorio e Concetti di Virtualizzazione . . 35
18.2 2. Hypervisor e Sistemi Operativi Utilizzati 36
18.3 3. Gestione delle Reti Virtuali in VirtualBox 36
18.4 4. Virtualizzazione vs Containerizzazione 36
18.5 5. Architettura del Laboratorio di Pentesting 37

19 Classificazione dei Test di Penetration Testing: Black Box, White Box e Grey Box 37
19.1 1. Black Box Testing (Test a Scatola Nera) 37
19.2 2. White Box Testing (Test a Scatola Bianca) 38
19.3 3. Grey Box Testing (Test a Scatola Grigia) 38

20 M5: Information Gathering nel Penetration Testing 38
20.1 1. Introduzione e Metodologia OSINT 38
20.2 2. Google Hacking e Google Dorks 39
20.3 3. Analisi Storica e Pagine in Cache 39
20.4 4. Social Media e Annunci di Lavoro 39
20.5 5. Estrazione dei Metadati 39
20.6 6. Query DNS e Laboratorio OPNsense 39
20.7 7. DNS Zone Transfer (AXFR) 40
20.8 8. Strumenti di Automazione 40
20.9 9. Ricerca di Dispositivi con Shodan 40

21 M6: Network Scanning **40**
21.1 Scansione a Livello 2 (Data Link Layer) 40
21.2 Scansione a Livello 3 (Network Layer) e Nmap 41
21.2.1 Host Discovery / Ping Sweep 41
21.2.2 Le 11 Fasi di Nmap 41
21.3 Struttura dei Pacchetti e Flag TCP 41
21.4 Scansioni a Livello 4 (Transport Layer – Porte e Servizi) 42

22 M7: Banner Grabbing e OS Fingerprinting **42**
22.1 Banner Grabbing dei Servizi (HTTP e FTP) 42
22.1.1 Interazione con Web Server (HTTP) 42
22.1.2 Interazione con Server FTP 43
22.1.3 Offuscamento del Banner (Banner Obfuscation) 43
22.2 Nmap Service Probes 43
22.3 Operating System Detection (OS Fingerprinting) 44
22.3.1 Modalità Attiva (Active Mode) 44
22.3.2 Modalità Passiva (Passive Mode) 44

23 M8: Enumeration **44**
23.1 1. Concetti Fondamentali e Servizi Target 45
23.2 2. Enumerazione SAMBA e NetBIOS 45
23.2.1 Nmap e NSE Scripts 45
23.2.2 rpcclient 46
23.2.3 enum4linux 46
23.3 3. Enumerazione SMTP 46
23.3.1 Comandi SMTP Tramite Telnet 46
23.3.2 Enumerazione Automatizzata 47
23.4 4. Enumerazione Apache UserDir 47
23.5 5. Enumerazione Tramite Credenziali di Default 47
23.6 6. Enumerazione Tramite Vulnerabilità SQL Injection 48
23.6.1 In-Band SQL Injection 48
23.6.2 Blind SQL Injection 48
23.6.3 Interrogazione dello Schema 48
23.6.4 Ricerca Binaria 48

24 M9: Vulnerability Assessment **49**
24.1 Vulnerability Assessment e Penetration Testing 49
24.2 Il Ruolo del Proof-of-Concept (PoC) 49
24.3 Metodologie di Individuazione delle Vulnerabilità 49
24.4 Vulnerability Scanner Automatici 50
24.5 Quality of Detection (QoD) 50
24.6 Vulnerabilità Applicative e Software Custom 50

25 Cross-Site Scripting (XSS) **51**
25.1 Tipologie di XSS 51
25.1.1 Reflected XSS 51
25.1.2 Stored XSS 51
25.2 Tainted Flows e Contesti HTML 51
25.3 Bypass della Sanitizzazione 52
25.4 Client-Side Exploitation e BeEF 52

26 SQL Injection (SQLi) **52**
26.1 Tecniche di Rilevamento 52
26.2 In-Band SQL Injection 53
26.3 Blind SQL Injection 53
26.4 Interrogazione dello Schema 53
26.5 Ricerca Binaria e Time-Based SQLi 53
26.6 Funzioni SQL Utilizzate nei Test 54
26.7 DBMS e Banner Grabbing 54
26.8 Automazione con SQLMap 54

27 M10: Exploitation **54**
27.1 Dalla Vulnerability Assessment all'Exploitation 55
27.2 Exploit, Attacchi e Decision Trees 55
27.2.1 Exploit 55
27.2.2 Attacco 55
27.2.3 Decision Trees 56
27.3 Controllo Remoto e Persistenza 56
27.4 Client-Side Exploitation 56
27.5 Framework e Strumenti di Analisi 57
27.5.1 Browser Exploitation Framework 57
27.5.2 Metasploit Framework 57
27.5.3 Meterpreter 57
27.6 Laboratori e Simulazioni 57
27.7 Considerazioni Finali 58

28 M11: Post-Exploitation **58**
28.1 Le Attività Fondamentali della Post-Exploitation 58
28.2 Privilege Escalation 59
28.2.1 Obiettivi 59
28.2.2 Recupero delle Credenziali 59
28.2.3 Ricerca di Errate Configurazioni 59
28.3 Mantenimento dell'Accesso 59
28.3.1 Process Migration 60
28.3.2 Tecniche di Persistenza 60
28.4 Data Collection 60
28.5 Internal Network Mapping 61
28.6 Movimento Laterale 61
28.7 La Natura Ciclica dell'Attacco 61

28.8 Obiettivi della Post-Exploitation 62

29 M12: The Final Report **62**
29.1 Struttura Generale del Report 62
29.2 Executive Summary 63
29.3 Definizione dello Scope 63
29.4 Descrizione delle Attività Svolte 63
29.5 Metodologie e Standard di Riferimento 64
29.6 Valutazione del Rischio mediante CVSS 64
29.7 Documentazione delle Vulnerabilità 65
29.8 Evidenze e Replicabilità 65
29.9 Piano di Remediation 65
29.9.1 Patch 66
29.9.2 Mitigation 66
29.9.3 Workaround 66
29.10 Prioritizzazione degli Interventi 66
29.11 Conclusioni 67

1 Introduzione all'Ethical Hacking

1.1 Concetti Fondamentali

Il modulo **M1 – Intro** (*Hacking and Security: Introduction to Ethical Hacking*) introduce i concetti chiave, i requisiti professionali e la metodologia di base dell'Ethical Hacking e del Penetration Testing.

1.1.1 Introduzione all'Ethical Hacking

Contesto e Crescita Professionale La figura dell'ethical hacker ha acquisito crescente rilevanza a causa dell'aumento degli attacchi informatici e della maggiore attenzione mediatica verso la cybersecurity. L'ethical hacker è un professionista esperto incaricato di testare e rafforzare le difese di qualsiasi tipo di infrastruttura.

Etica dell'Hacker La distinzione tra hacker etico e malizioso risiede nell'autorizzazione:

- L'ethical hacker opera esclusivamente su commissione del cliente e riporta i risultati solo a quest'ultimo.
- L'hacker malizioso agisce per profitto personale a discapito delle vittime.

Ethical Hacker vs. Security Engineer

- **Security Engineer**: si concentra sulla difesa dell'infrastruttura (firewall, IDS/IPS, best practices).
- **Ethical Hacker**: adotta la prospettiva dell'attaccante e si specializza nell'esecuzione di penetration test.

Accordo e Scope Prima dell'inizio di un test è necessario definire lo **scope**, ovvero l'ambito autorizzato dell'analisi e i limiti da non superare.

Competenze Necessarie

1. **Reti Informatiche**: comprensione dei concetti fondamentali.
2. **Programmazione**: conoscenza di almeno un linguaggio; Python è consigliato per semplicità e ampia disponibilità di librerie.

Vettori d'Attacco Sottovalutati Dispositivi mobili (smartphone, tablet) connessi alla rete aziendale rappresentano potenziali punti di ingresso per un attaccante.

1.2 Fasi di un Attacco di Rete

Un cyberattacco segue un processo strutturato composto da più fasi. Maggiore è il tempo dedicato a ciascuna fase, più efficace sarà l'attacco.

1.2.1 Sequenza Generale

1. Raccolta delle informazioni (Information Collection)
2. Scansione di rete (Network Scanning)
3. Accesso alla rete (Access to the Network)
4. Mantenimento dell'accesso (Maintaining Access)
5. Cancellazione dei log

1.2.2 Metodologia Professionale del Penetration Testing

A. Information Gathering Raccolta di informazioni sul target tramite **OSINT**, senza interazione diretta con l'infrastruttura.

B. Network Scanning Mappatura delle porte e dei servizi esposti. In questa fase inizia l'interazione diretta con il target, con rischio di rilevamento.

C. Enumeration Analisi dettagliata dei servizi individuati per estrarre informazioni specifiche (utenti, condivisioni, risorse).

D. Vulnerability Assessment Identificazione e conferma delle vulnerabilità tramite **Proof-of-Concept (PoC)**, exploit minimali che dimostrano la falla senza causare danni.

E. Exploitation Sfruttamento attivo delle vulnerabilità per ottenere accesso iniziale e valutare il *worst-case scenario*.

F. Post-Exploitation Stabilizzazione dell'accesso ottenuto tramite meccanismi di persistenza affidabili.

G. Final Report Documento conclusivo che descrive attività svolte, vulnerabilità riscontrate e piano di remediation. Un report poco chiaro può compromettere l'intera campagna di test.

1.3 Considerazioni Metodologiche

Astrazione La metodologia presentata è astratta: diversi framework adottano terminologie differenti ma condividono le stesse fasi concettuali.

Flessibilità ed Engagement Le attività dipendono dalle regole di ingaggio concordate con il cliente. Alcuni test possono escludere exploitation e post-exploitation, limitandosi alla sola valutazione delle vulnerabilità.

2 Il Modello ISO/OSI

2.1 Introduzione

Il modello **ISO-OSI** (*Open Systems Interconnection*) è una formulazione teorica che suddivide la comunicazione di rete in sette livelli distinti. Pur essendo una classificazione convenzionale, risulta estremamente utile per identificare con precisione il livello su cui si sta operando durante l'analisi di rete o un'attività di Penetration Testing.

2.2 I Sette Livelli del Modello

Di seguito vengono descritti i sette livelli, dal più basso al più alto.

2.2.1 1. Physical Layer (Livello Fisico)

Questo livello riguarda il trasferimento dei bit attraverso un **mezzo fisico** (cavi in rame, fibra ottica, onde radio).

- *Esempio pratico*: sostituire un cavo di rete danneggiato per ripristinare la connettività.

2.2.2 2. Data Link Layer (Livello di Collegamento Dati)

Gestisce la comunicazione all'interno delle **reti locali (LAN)**.

Indirizzo MAC Identificativo univoco a 48 bit assegnato dal produttore della scheda di rete. A questo livello i dispositivi comunicano esclusivamente tramite MAC address.

Protocollo ARP L'**Address Resolution Protocol** associa indirizzi MAC (Data Link) e indirizzi IP (Network). È considerato un protocollo *cross-layer* poiché opera su logiche di entrambi i livelli.

2.2.3 3. Network Layer (Livello di Rete)

Si occupa dell'instradamento dei pacchetti tra reti diverse.

Internet Protocol (IP) Protocollo principale del livello Network.

Indirizzo IP Valore numerico a 32 bit (IPv4) che identifica la rete e l'host. A differenza dei MAC address, consente la comunicazione al di fuori della subnet tramite router.

2.2.4 4. Transport Layer (Livello di Trasporto)

Gestisce lo **scambio e il flusso dei dati** tra host.

TCP (Transmission Control Protocol) Protocollo **orientato alla connessione** e affidabile. Richiede l'instaurazione di una sessione tramite il *Three-way handshake* (flag SYN e ACK).

UDP (User Datagram Protocol) Protocollo **connectionless**, privo di garanzie sull'arrivo dei pacchetti ma estremamente rapido ed efficiente.

2.2.5 5. Session Layer (Livello di Sessione)

Stabilisce e mantiene le sessioni di comunicazione tra applicazioni.

- *Esempio*: **NetBIOS**, utilizzato per l'esplorazione di risorse condivise in ambienti Windows/Samba.

2.2.6 6. Presentation Layer (Livello di Presentazione)

Si occupa della traduzione, formattazione, compressione e cifratura dei dati affinché siano correttamente interpretati dall'applicazione ricevente.

2.2.7 7. Application Layer (Livello di Applicazione)

Rappresenta l'interfaccia diretta con l'utente e i software. Qui operano i protocolli ad alto livello.

- **HTTP/HTTPS**: navigazione web.
- **FTP**: trasferimento file.

2.3 Nota Operativa per il Penetration Testing

Ai fini pratici dell'analisi delle reti e delle attività di Penetration Testing, i livelli di **Sessione (5)** e **Presentazione (6)** sono generalmente meno rilevanti. La maggior parte delle tecniche di scansione e dei protocolli critici opera infatti sui livelli:

- Fisico (1)
- Data Link (2)
- Network (3)
- Transport (4)
- Application (7)

3 L'Indirizzo MAC (Media Access Control)

3.1 Introduzione

L'indirizzo **MAC** è un identificatore a 48 bit assegnato in modo univoco dal produttore a ogni scheda di rete, sia Ethernet che wireless. Opera nel contesto delle reti locali e costituisce un elemento fondamentale del livello *Data Link* del modello ISO/OSI.

3.2 1. Livello di Funzionamento e Ambito Locale

Layer 2 (Data Link) L'indirizzo MAC opera nel livello di collegamento dati, responsabile della comunicazione all'interno delle **LAN**.

Identificazione Locale All'interno di una stessa subnet, i dispositivi utilizzano i rispettivi MAC address per identificarsi e scambiare dati direttamente. La sua utilità è quindi limitata al contesto locale.

Differenza con l'Indirizzo IP A differenza del MAC, l'indirizzo IP permette la comunicazione tra reti diverse. Il MAC:

- non identifica globalmente un dispositivo su Internet;
- può essere falsificato (spoofing);
- è necessario per la comunicazione locale.

Per comunicare al di fuori della LAN, ogni scheda di rete deve avere un indirizzo IP associato (tipicamente tramite DHCP).

3.3 2. Ruolo dello Switch e i Frame Ethernet

Frame Ethernet I pacchetti locali (frame) contengono:

- MAC del mittente;
- MAC del destinatario.

CAM Table Gli switch Ethernet apprendono automaticamente la topologia della LAN registrando le associazioni tra:

- porte fisiche,
- indirizzi MAC dei dispositivi connessi.

Queste informazioni vengono memorizzate nella **CAM (Content Addressable Memory)**. Lo switch inoltra i frame solo alla porta corretta, evitando trasmissioni in broadcast non necessarie.

3.4 3. Transizione da MAC a IP: Il Protocollo ARP

ARP (Address Resolution Protocol) Poiché la comunicazione locale richiede il MAC, mentre quella geografica richiede l'IP, è necessario un meccanismo di traduzione. Il protocollo **ARP** gestisce il mapping tra:

- indirizzi IP (Layer 3),
- indirizzi MAC (Layer 2).

Le tabelle ARP memorizzano temporaneamente le coppie IP–MAC dei dispositivi presenti nella rete locale.

3.5 4. Come Visualizzare l'Indirizzo MAC

A seconda del sistema operativo, è possibile visualizzare il MAC address tramite i seguenti comandi:

- **Unix/Linux moderni**: `ip addr`
- **Unix/Linux meno recenti**: `ifconfig -a`
- **Windows**: `ipconfig /all`

3.6 Nota Operativa

L'indirizzo MAC è fondamentale per comprendere:

- il funzionamento delle LAN,
- la logica degli switch,
- i meccanismi di ARP,
- tecniche di attacco come ARP spoofing e MAC flooding.

4 L'Indirizzo IP (Internet Protocol)

4.1 Introduzione

Un **indirizzo IP** è un identificativo numerico che permette di individuare in modo univoco sia la rete di appartenenza di un dispositivo, sia l'host specifico all'interno di quella rete. Senza un indirizzo IP, un dispositivo non può comunicare al di fuori della propria sottorete locale né accedere a Internet.

4.2 1. Struttura dell'Indirizzo IPv4

Gli indirizzi IPv4 sono composti da **32 bit** (4 byte), rappresentati in notazione decimale puntata (ad esempio: `69.89.31.226`). Un indirizzo IP si divide logicamente in due parti:

1. **Network ID**: identifica la rete di appartenenza.
2. **Host ID**: identifica il dispositivo all'interno della rete.

4.2.1 Classi di Indirizzi Classful

Storicamente, lo spazio IPv4 è suddiviso in cinque classi principali:

- **Classe A**: `0.0.0.0` – `127.255.255.255`
- **Classe B**: `128.0.0.0` – `191.255.255.255`
- **Classe C**: `192.0.0.0` – `223.255.255.255`
- **Classe D (Multicast)**: `224.0.0.0` – `239.255.255.255`
- **Classe E (Sperimentale)**: `240.0.0.0` – `255.255.255.255`

Loopback Range L'intervallo `127.0.0.0` – `127.255.255.255` è riservato ai test locali (`127.0.0.1`).

4.2.2 Subnetting e Notazione CIDR

La maschera di sottorete definisce quanti bit identificano la rete. Esempio: `192.168.1.0/24`

- i primi 24 bit identificano la rete;
- gli ultimi 8 bit identificano gli host.

La subnet `/24` (maschera `255.255.255.0`) permette **254 host utilizzabili**. Altre maschere comuni:

- `/30`: 2 host utilizzabili (collegamenti punto-punto)
- `/28`: 14 host utilizzabili (maschera `255.255.255.240`)

4.3 2. Indirizzi IP Pubblici e Privati

Indirizzi Pubblici Instradabili globalmente su Internet; devono essere univoci a livello mondiale.

Indirizzi Privati Utilizzati esclusivamente nelle reti locali. Non sono instradabili su Internet e possono essere riutilizzati da qualsiasi organizzazione.

Spazi di indirizzamento privato:

- **Classe A**: `10.0.0.0` – `10.255.255.255`
- **Classe B**: `172.16.0.0` – `172.31.255.255`
- **Classe C**: `192.168.0.0` – `192.168.255.255`

4.4 3. Meccanismi di Rete Essenziali

4.4.1 NAT (Network Address Translation)

I dispositivi con IP privato non possono comunicare direttamente con Internet. Il router traduce l'IP privato in un unico IP pubblico tramite NAT, mantenendo una mappatura interna delle porte per instradare correttamente il traffico di ritorno. Questo meccanismo:

- permette a molti host di condividere un solo IP pubblico;
- nasconde la struttura interna della rete, offrendo sicurezza passiva.

4.4.2 Default Gateway

Dispositivo (tipicamente un router) verso cui un host invia i pacchetti destinati a reti esterne alla propria subnet.

4.4.3 DHCP (Dynamic Host Configuration Protocol)

Protocollo che assegna automaticamente:

- indirizzo IP,
- subnet mask,
- default gateway,
- server DNS.

Il processo include pacchetti come `DHCPDISCOVER` e `DHCPOFFER`.

4.4.4 DNS (Domain Name System)

Sistema che traduce nomi di dominio (es. `www.google.com`) nei rispettivi indirizzi IP numerici.

4.5 4. Comandi Utili per l'Amministrazione degli IP

Visualizzare l'IP Privato

- **Windows**: `ipconfig`, `ipconfig /all`
- **Unix/Linux**: `ip addr`, `ifconfig -a`

Tabella di Routing / Default Gateway

- **Windows**: `route print`
- **Unix/Linux**: `route -n`

Risoluzione DNS `nslookup <nome_host>`

4.6 5. IPv6: L'Evoluzione

IPv6 utilizza indirizzi a **128 bit** in notazione esadecimale, offrendo uno spazio di indirizzamento enormemente superiore.

Tipologie principali:

- **Link-local**: `fe80::/10`
- **Global Unicast**: `2000::/3`
- **IPv4-Mapped**: `::ffff:a.b.c.d`

5 Il Protocollo ARP (Address Resolution Protocol)

5.1 Introduzione

Il protocollo **ARP (Address Resolution Protocol)** è fondamentale per il funzionamento delle reti locali. La sua funzione principale è risolvere e mantenere l'associazione tra:

- indirizzo IP (Layer 3 – Network),
- indirizzo MAC (Layer 2 – Data Link).

L'ARP permette ai dispositivi di comunicare correttamente all'interno della stessa subnet, traducendo gli indirizzi logici (IP) in indirizzi fisici (MAC).

5.2 1. Ruolo e Posizionamento nella Pila ISO/OSI

Protocollo Cross-Layer L'ARP opera a cavallo tra il livello Data Link e il livello Network, motivo per cui viene definito *cross-layer*.

Contesto Locale L'ARP funziona esclusivamente all'interno della stessa rete locale. Le applicazioni utilizzano indirizzi IP, ma la comunicazione fisica avviene tramite frame Ethernet basati su MAC address. L'ARP svolge il ruolo di traduttore tra questi due livelli.

5.3 2. Meccanismo di Funzionamento

Quando un host A deve comunicare con un host B nella stessa LAN e conosce solo l'indirizzo IP di B, interviene l'ARP.

1. ARP Request L'host A invia un pacchetto ARP in **broadcast**:

Who has IP_B? Tell IP_A

Tutti i dispositivi della LAN ricevono la richiesta.

2. ARP Reply Solo il dispositivo con indirizzo IP_B risponde, inviando un pacchetto ARP in **unicast**:

IP_B is at MAC_B

3. ARP Table (ARP Cache) L'host A memorizza la coppia IP–MAC nella propria tabella ARP, evitando future richieste broadcast.

5.4 3. Gestione e Visualizzazione della Tabella ARP

La tabella ARP contiene le associazioni IP–MAC apprese dinamicamente. È possibile visualizzarla tramite:

- **Windows**: `arp -a`
- **Unix/Linux**: `arp -a`

La tabella mostra:

- indirizzi IP,
- indirizzi MAC corrispondenti,
- tipo di associazione (dinamica o statica).

5.5 4. ARP nel Troubleshooting di Rete

L'analisi della tabella ARP è utile per diagnosticare problemi di connettività.

Caso 1: Voce ARP Presente Se un host non risponde al `PING`, ma la voce ARP è presente:

- la comunicazione a livello Data Link funziona;
- il problema è probabilmente a livello Network o dovuto a un firewall.

Caso 2: Voce ARP Assente o Incompleta Se la voce ARP non è presente:

- il problema è a livello fisico o Data Link;
- il dispositivo potrebbe essere spento, scollegato o non raggiungibile.

5.6 5. ARP nel Network Scanning

Arping Strumento che invia richieste ARP per verificare la presenza di un host e ottenere il suo MAC:

```
arping <IP> -c 4 -I <interfaccia>
```

Nmap (Host Discovery) Nmap utilizza ARP per scoprire gli host attivi nella LAN:

- opzione: `-sn`
- scansione veloce e affidabile, più efficace delle scansioni ICMP.

Poiché il traffico ARP è indispensabile per la connettività locale, raramente viene filtrato, rendendo le scansioni ARP estremamente efficaci.

5.7 Nota Operativa

L'ARP è centrale per:

- la comunicazione locale,
- la diagnostica di rete,
- la mappatura delle LAN,
- la comprensione di attacchi come ARP Spoofing e ARP Poisoning.

6 Il Default Gateway

Il **default gateway** è un dispositivo di rete fondamentale che consente la comunicazione tra reti o sottoreti differenti. Quando un host deve inviare pacchetti al di fuori della propria rete locale, il gateway predefinito rappresenta il punto di riferimento verso l'esterno.

6.1 Funzione e Utilità

- **Comunicazione nella rete locale**: All'interno della LAN, i dispositivi utilizzano il protocollo ARP per associare indirizzi IP ai corrispondenti indirizzi MAC. Questo meccanismo è sufficiente finché la comunicazione rimane nella stessa sottorete.
- **Accesso a reti esterne**: Quando un host deve raggiungere dispositivi situati in altre sottoreti o su Internet, è necessario inoltrare i pacchetti a un router. Il default gateway è definito come il "dispositivo migliore" a cui affidare l'instradamento verso l'esterno.

- **Meccanismo di inoltro**: Se un host non conosce la route verso un indirizzo IP esterno, oppure rileva che il destinatario non appartiene alla propria sottorete, invia il pacchetto direttamente al default gateway. Il router analizza l'intestazione IP e si occupa dell'inoltro verso la destinazione corretta.

6.2 Esempio Pratico e Configurazione

- **Instradamento di un pacchetto**: Un esempio tipico prevede un host che, per raggiungere un indirizzo esterno alla propria rete, inoltra il pacchetto al gateway configurato con indirizzo IP `10.0.2.2`.
- **Distribuzione tramite DHCP**: Configurare manualmente parametri come IP, subnet mask, DNS e default gateway su numerosi dispositivi è inefficiente e soggetto a errori. Per questo motivo, il default gateway viene generalmente assegnato in modo automatico tramite un server DHCP.

6.3 Come Individuare il Default Gateway

- **Sistemi Windows**: È possibile visualizzare il gateway predefinito tramite il comando `ipconfig`. In alternativa, il comando `route print` permette di analizzare l'intera tabella di routing.
- **Sistemi Unix/Linux**: Il comando `route -n` mostra la tabella di routing in formato numerico. Informazioni analoghe possono essere ottenute anche con il comando `route`.

7 Il Network Address Translation (NAT)

Il **Network Address Translation** (NAT) è un meccanismo essenziale implementato nei router per consentire ai dispositivi di una rete locale di comunicare con l'esterno e accedere a Internet. La traduzione degli indirizzi permette a più host privati di condividere uno o pochi indirizzi IP pubblici.

7.1 Perché è necessario il NAT

All'interno delle reti private, ai dispositivi vengono assegnati **indirizzi IP privati** (ad esempio nella classe C `192.168.1.0/24`). Questi indirizzi sono validi per la comunicazione interna, ma **non sono instradabili su Internet**. Per accedere a risorse esterne è indispensabile un **indirizzo IP pubblico**.

Lo spazio degli indirizzi IPv4 è limitato a circa 4,3 miliardi di combinazioni, oggi quasi completamente esaurite. Non è quindi possibile assegnare un IP pubblico univoco a ogni dispositivo. Il NAT risolve questo problema permettendo a intere reti locali di **condividere uno o pochi indirizzi IP pubblici**.

7.2 Funzionamento della Traduzione: Un Esempio

Quando un host interno invia una richiesta verso Internet:

1. Il dispositivo sorgente utilizza un indirizzo privato, ad esempio `192.168.1.10`.
2. La richiesta raggiunge il router della rete locale.
3. Il router intercetta il pacchetto e **sostituisce l'indirizzo IP privato con il proprio indirizzo IP pubblico**, ad esempio `34.34.23.12`.
4. La risorsa esterna risponde all'indirizzo pubblico del router.
5. Il router effettua nuovamente la traduzione, rimappando l'IP pubblico verso l'IP privato del dispositivo originario.

7.3 Condivisione dell'IP Pubblico e Port Mapping

In una rete domestica o aziendale, più dispositivi possono condividere lo stesso IP pubblico. Per distinguere correttamente le comunicazioni, il NAT utilizza le **porte di comunicazione**:

- Sebbene all'esterno tutte le richieste sembrino provenire dallo stesso IP pubblico, ciascuna utilizza un **numero di porta differente**.
- Il router mantiene una **tabella di associazione dinamica** che collega porte esterne e indirizzi IP privati interni.
- Solo il dispositivo NAT conosce questa tabella e può rimappare correttamente le risposte verso i dispositivi interni.

7.4 Vantaggi Principali del NAT

- **Risparmio di Indirizzi IP**: Riduce drasticamente la necessità di indirizzi pubblici, permettendo a reti molto estese di utilizzare pochi IP globali.
- **Sicurezza e Privacy**: Gli indirizzi privati non vengono mai esposti all'esterno. Un attaccante vede solo l'IP pubblico del router, senza alcuna informazione sulla struttura interna della rete o sulle associazioni tra porte e dispositivi.

8 Il Domain Name System (DNS)

Il **Domain Name System** (DNS) è un servizio fondamentale per il funzionamento delle reti moderne. Poiché gli indirizzi IP numerici non sono facilmente memorizzabili dagli utenti, il DNS funge da "traduttore" che associa a ciascun indirizzo IP un nome simbolico (hostname o URL), rendendo più semplice l'accesso alle risorse. Ad esempio, invece di digitare l'indirizzo IP `34.25.7.34`, l'utente può utilizzare il nome `www.google.com`.

8.1 Struttura Gerarchica del DNS

Il DNS è organizzato secondo una **struttura gerarchica e distribuita**. Quando un client effettua una richiesta di risoluzione:

- Se il server DNS locale non possiede la risposta nella propria cache, la query viene inoltrata verso livelli superiori della gerarchia.
- La risoluzione può risalire fino ai **Root Name Server**, che indirizzano il client verso i server autorevoli del dominio richiesto.

8.2 DNS Pubblici e DNS Privati

I server DNS si dividono in due categorie principali:

- **DNS Pubblici**: Gestiscono la risoluzione dei nomi dei siti web e delle risorse accessibili su Internet.
- **DNS Privati**: Utilizzati all'interno di reti aziendali o locali per mappare risorse interne (server, stampanti, servizi intranet) verso indirizzi IP privati. È possibile, ad esempio, configurare un server DNS interno (come *Unbound DNS* su OPNsense) per associare un dominio fittizio, come `pentest.com`, all'indirizzo IP di un server locale.

8.3 Protocolli e Porte

Il DNS utilizza la **porta 53** e opera tramite due protocolli di trasporto:

- **UDP**: Utilizzato per le normali query di risoluzione, rapide e non orientate alla connessione.
- **TCP**: Impiegato per operazioni che richiedono affidabilità, come i **trasferimenti di zona** (Zone Transfer).

8.4 Strumenti di Interrogazione DNS

Sono disponibili diversi strumenti a riga di comando per analizzare e interrogare i server DNS:

- `nslookup`: Comando comune su Windows e Linux per verificare la corrispondenza tra hostname e indirizzo IP.
- `ipconfig /displaydns`: Mostra la cache DNS locale su sistemi Windows.
- `dig`: Strumento avanzato per Linux che permette interrogazioni dettagliate dei record DNS.
- `host`: Utility Unix per lookup rapidi di nomi e indirizzi IP.

8.5 Trasferimento di Zona (DNS Zone Transfer) e Sicurezza

Il DNS riveste un ruolo importante nelle attività di analisi e Penetration Testing, in particolare nella fase di *Information Gathering*.

- **Zone Transfer (AXFR)**: Consiste nel richiedere a un server DNS l'intera lista dei record presenti nel suo database. Questa operazione è utilizzata per sincronizzare server primari e secondari, ma se non protetta può esporre informazioni sensibili sulla struttura interna della rete.
- **Esecuzione**: Un trasferimento di zona può essere tentato con:

  ```
  dig @<IP_DNS> <dominio> AXFR
  ```

- **Rischi**: Un AXFR non autorizzato può rivelare tutti i sottodomini, gli indirizzi IP e i servizi interni. Inoltre, risposte voluminose possono essere sfruttate per attacchi DoS tramite amplificazione.
- **Automazione**: Strumenti come `dnsrecon.py` permettono di automatizzare la raccolta dei record, tentare trasferimenti di zona ed effettuare brute-force dei sottodomini.

9 Il Protocollo DHCP (Dynamic Host Configuration Protocol)

Il **DHCP** è il protocollo standard utilizzato per la configurazione dinamica degli indirizzi IP e dei parametri di rete essenziali per gli host. Esso automatizza completamente la distribuzione delle configurazioni, eliminando la necessità di interventi manuali da parte degli amministratori di rete.

9.1 Motivazioni e Obiettivi

In assenza di DHCP, la configurazione degli indirizzi IP deve essere eseguita manualmente tramite IP statici. In contesti aziendali con centinaia o migliaia di dispositivi, ciò comporta diversi svantaggi:

- **Enorme spreco di tempo**: ogni postazione richiederebbe una configurazione manuale di IP, gateway e DNS.
- **Rischio di collisioni**: l'errore umano può portare all'assegnazione dello stesso indirizzo IP a più host.
- **Spreco di indirizzi**: gli IP rimarrebbero assegnati anche a dispositivi che si connettono raramente.

- **Scarsa flessibilità**: ogni variazione dei parametri di rete richiederebbe una riconfigurazione completa degli host.

Il DHCP risolve questi problemi centralizzando e automatizzando l'intero processo di assegnazione degli indirizzi IP.

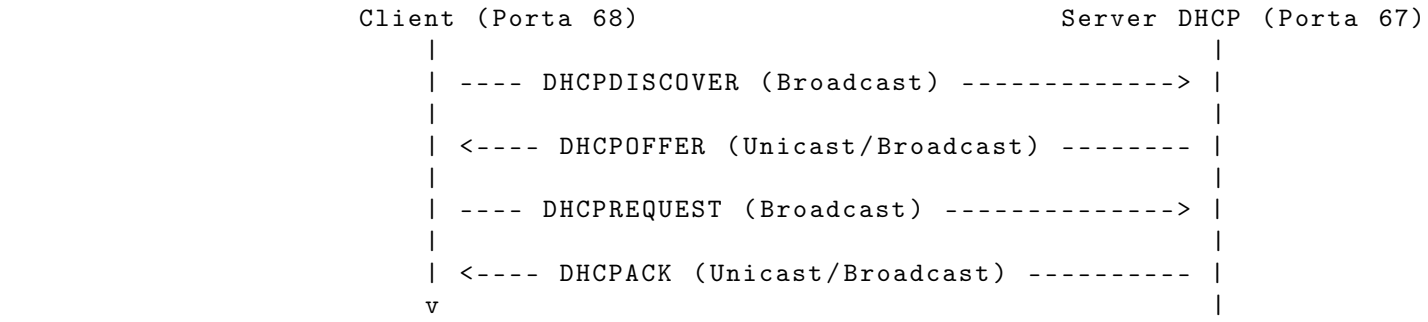
9.2 Porte e Protocollo di Trasporto

Il DHCP utilizza il protocollo UDP a livello di trasporto e fa uso delle seguenti porte:

- **UDP 67**: porta utilizzata dal server DHCP.
- **UDP 68**: porta utilizzata dal client DHCP.

9.3 La Sequenza DORA

L'assegnazione automatica di un indirizzo IP avviene tramite uno scambio standardizzato di quattro messaggi tra client e server, noto come sequenza **DORA** (Discover, Offer, Request, Acknowledge).



9.3.1 DHCPDISCOVER (Scoperta)

Il client, privo di un indirizzo IP (sorgente `0.0.0.0`), invia un messaggio **DHCPDISCOVER** in broadcast verso `255.255.255.255`. Il pacchetto include:

- l'indirizzo MAC del client;
- un identificativo di transazione (Transaction ID).

9.3.2 DHCPOFFER (Offerta)

Ogni server DHCP che riceve la richiesta risponde con un **DHCPOFFER** contenente:

- l'indirizzo IP proposto (`yiaddr`);
- il Transaction ID;

- l'indirizzo del server DHCP;
- il tempo di lease, subnet mask, gateway e DNS.

9.3.3 DHCPREQUEST (Richiesta)

Il client seleziona una delle offerte ricevute e invia un **DHCPREQUEST** in broadcast per:

1. confermare l'accettazione dell'offerta scelta;
2. notificare agli altri server che le loro offerte sono state rifiutate.

9.3.4 DHCPACK (Conferma)

Il server conferma l'assegnazione tramite un **DHCPACK**, che contiene l'indirizzo IP finale e tutti i parametri di rete. A questo punto il client configura la propria interfaccia e può comunicare sulla rete.

9.4 Comandi Utili e Diagnostica

9.4.1 Configurazione DHCP su Windows

Per configurare un'interfaccia affinché utilizzi il DHCP:

```
netsh interface ip set address name="<NOME_INTERFACCIA>" source=dhcp
```

9.4.2 Log DHCP su Linux/Unix

Per analizzare le assegnazioni DHCP nei log di sistema:

```
cat /var/log/messages | grep DHCP
```

10 Porte e Servizi nelle Reti: Concetti Fondamentali per l'Ethical Hacking

Nel contesto della sicurezza informatica e dell'ethical hacking, i concetti di **porta** e **servizio** sono strettamente correlati. Le porte rappresentano punti di accesso logici utilizzati dai protocolli di rete, mentre i servizi sono i programmi o demoni software in ascolto su tali porte, pronti a gestire le richieste in arrivo.

10.1 Classificazione delle Porte

Ogni sistema dispone di un totale di 65535 porte. Esse si suddividono in:

- **Well-Known Ports (0–1024)**: Porte riservate ai servizi standard (es. FTP, SSH, HTTP).

- **Porte Registrate e Dinamiche (>1024)**: Utilizzate da servizi meno comuni o come porte effimere dai client.

Per un penetration tester, ottenere la lista delle porte aperte su un host rappresenta il punto di partenza per identificare i servizi attivi, le loro versioni e le eventuali vulnerabilità.

10.2 Servizi e Porte Standard

10.2.1 Navigazione Web e Trasferimento File

- **TCP 20**: FTP Data Connection.
- **TCP 21**: FTP Control Connection.
- **UDP 69**: TFTP.
- **TCP 80**: HTTP.
- **TCP 443**: HTTPS.

10.2.2 Accesso Remoto e Amministrazione

- **TCP 22**: SSH / SCP.
- **TCP 23**: Telnet.
- **TCP 3389**: RDP.
- **TCP 5900**: VNC.

10.2.3 Servizi Infrastrutturali di Rete

- **TCP/UDP 53**: DNS.
- **UDP 67–68**: DHCP / BOOTP.
- **UDP 123**: NTP.
- **UDP 161–162**: SNMP.

10.2.4 Posta Elettronica

- **TCP 25**: SMTP.
- **TCP 587**: SMTP Submission.
- **TCP 110**: POP3.
- **TCP 143**: IMAP4.

10.2.5 Condivisione Risorse e Directory (Windows/Samba)

- **TCP 88**: Kerberos.
- **TCP 135**: Windows RPC.
- **UDP 137–138**: NetBIOS Name e Datagram Service.
- **TCP 139**: NetBIOS Session Service.
- **TCP 445**: SMB.
- **TCP 389**: LDAP.

10.2.6 Database Relazionali

- **TCP/UDP 1433–1434**: MS-SQL.
- **TCP 1521**: Oracle.
- **TCP 3306**: MySQL.
- **TCP 5432**: PostgreSQL.

10.3 Sistemi Industriali (ICS/SCADA)

- **TCP 502**: Modbus TCP.
- **TCP/UDP 4840**: OPC UA Discovery.
- **TCP/UDP 20000**: DNP3.

10.4 Firewall, NAT e Port Forwarding

- **Filtraggio del traffico**: I firewall analizzano IP sorgente/destinazione e porte per applicare regole di blocco o consenso.
- **NAT**: Quando più dispositivi condividono un unico IP pubblico, il NAT distingue i flussi tramite porte diverse.

11 Diagnostica e Troubleshooting di Rete secondo il Modello ISO-OSI

Il processo di diagnostica delle reti segue una logica strutturata basata sui livelli del modello ISO-OSI. L'obiettivo è isolare in modo sistematico la causa di un problema di connettività, procedendo dal livello fisico fino ai livelli superiori.

11.1 1. Verifica Fisica (Physical Layer)

Il primo controllo riguarda il livello fisico:

- verificare che il cavo di rete sia correttamente collegato;
- controllare eventuali danni visibili al cavo;
- sostituire il cavo se necessario.

11.2 2. Verifica dell'Indirizzo IP (Network Layer)

Si verifica che al dispositivo sia stato assegnato un indirizzo IP valido:

- `ipconfig` su Windows;
- `ifconfig` o `ip addr` su sistemi Unix/Linux.

11.3 3. Test di Raggiungibilità: PING (Network Layer)

Si esegue un comando `ping` verso l'indirizzo IP del dispositivo bersaglio per verificarne la raggiungibilità. Il PING opera a livello Network e permette di stabilire se l'host risponde ai pacchetti ICMP.

11.4 4. Analisi ARP (Data Link Layer)

Se il PING non riceve risposta, si analizza la tabella ARP locale tramite:

```
arp -a
```

Le possibili interpretazioni sono:

- **Voce ARP presente**: il MAC address del target risulta noto. Il problema è probabilmente a livello Network (es. firewall).
- **Voce ARP assente**: il problema si colloca a livello Data Link (es. host non raggiungibile sul segmento locale).

11.5 5. Traceroute

Il comando `traceroute` (o l'opzione `-traceroute` di Nmap) permette di tracciare il percorso dei pacchetti verso un host remoto. Sebbene utile nelle analisi avanzate, nel troubleshooting locale immediato il flusso principale rimane:

$$\textbf{Cavo} \rightarrow \textbf{IP} \rightarrow \textbf{PING} \rightarrow \textbf{ARP}$$

12 GNS3: Simulazione ed Emulazione di Reti Informatiche

GNS3 (Graphical Network Simulator 3) è un software multipiattaforma, gratuito e open source (licenza GPL-3) progettato per la simulazione ed emulazione di reti informatiche. Sviluppato inizialmente da Jeremy Grossmann come progetto di tesi, rappresenta una nota alternativa a Cisco Packet Tracer.

12.1 1. Emulazione di Dispositivi e Topologie di Rete

- **Emulazione di hardware reale**: GNS3 consente di emulare router, switch, firewall e host, offrendo un comportamento molto vicino ai dispositivi fisici.
- **Costruzione di topologie**: I dispositivi possono essere collegati per creare architetture complesse, includendo LAN, WAN e DMZ.
- **Immagini e firmware**: L'emulazione richiede le immagini dei sistemi operativi dei dispositivi. Alcune sono disponibili nel repository ufficiale, mentre quelle proprietarie devono essere fornite dall'utente.

12.2 2. Integrazione con la Virtualizzazione

GNS3 permette di integrare diversi ambienti di virtualizzazione per arricchire la topologia:

- **Hypervisor supportati**: VirtualBox, QEMU e VMware.
- **Container Docker**: Possibilità di utilizzare container LXC, soluzione consigliata per ridurre il consumo di risorse rispetto alle macchine virtuali tradizionali.

12.3 3. Analisi del Traffico con Wireshark

- GNS3 integra direttamente lo sniffer di rete **Wireshark**.
- Cliccando con il tasto destro su un collegamento virtuale, è possibile avviare la cattura dei pacchetti in tempo reale per analizzare il traffico e il comportamento dei protocolli.

12.4 4. Gestione delle Risorse

Poiché GNS3 esegue sistemi operativi e firmware reali, il carico sulle risorse hardware può essere elevato. Il consumo di CPU e RAM dipende dal numero e dal tipo di nodi presenti nella topologia.

13 Segmentazione della Rete: LAN, WAN e DMZ

La segmentazione della rete consiste nel suddividere l'infrastruttura in aree distinte, ciascuna caratterizzata da specifiche proprietà e livelli di sicurezza. Questo approccio permette di organizzare il traffico, proteggere le risorse interne e gestire l'esposizione dei servizi verso l'esterno.

13.1 1. LAN (Local Area Network)

- **Concetto**: rappresenta il mondo interno dell'infrastruttura privata.
- **Caratteristiche**: ospita dispositivi e client interni, come workstation aziendali, configurati con indirizzi IP privati.
- **Sicurezza**: possiede il livello di protezione più elevato e non deve essere accessibile direttamente dalla WAN.

13.2 2. WAN (Wide Area Network)

- **Concetto**: rappresenta il mondo esterno.
- **Caratteristiche**: è la rete geografica utilizzata dai dispositivi interni per comunicare verso l'esterno, in particolare per accedere a Internet.

13.3 3. DMZ (Demilitarized Zone)

- **Concetto**: sottorete interposta tra LAN e WAN.
- **Caratteristiche**: ospita servizi che devono essere raggiungibili dall'esterno, come server web, server di posta o applicazioni aziendali. Spesso utilizza indirizzi IP statici o virtual IP.
- **Sicurezza**: mantiene un livello di protezione distinto dalla LAN. In caso di compromissione di un server in DMZ, la segmentazione impedisce l'accesso diretto alla rete interna.

13.4 Politiche di Flusso sul Firewall Perimetrale

Un firewall perimetrale (es. OPNsense o FortiGate) controlla il traffico tra le diverse zone applicando regole specifiche:

1. **LAN** $\rightarrow$ **WAN**: traffico generalmente consentito per permettere agli utenti interni di accedere a Internet.
2. **DMZ** $\leftrightarrow$ **WAN**: comunicazione regolata per consentire l'accesso ai servizi pubblicati nella DMZ.
3. **LAN** $\leftrightarrow$ **DMZ**: comunicazione controllata per permettere la gestione dei server presenti nella DMZ da parte degli amministratori interni.

14 Lo Switch: Funzionamento, Struttura e Ruolo nella LAN

Lo switch è un dispositivo fondamentale per consentire la comunicazione tra più macchine all'interno della stessa sottorete locale (LAN). Opera a livello 2 del modello OSI e utilizza gli indirizzi MAC per instradare i frame Ethernet in modo efficiente.

14.1 1. Ruolo e Ambito di Funzionamento

- **Operatività a livello di subnet**: lo switch opera esclusivamente all'interno di una singola sottorete, basandosi sugli indirizzi MAC.
- **Porte fisiche**: composto da più porte che fungono da interfacce di rete per i dispositivi collegati.
- **Impossibilità di routing**: uno switch non può collegare sottoreti differenti; per questo scopo è necessario un router.

14.2 2. Elaborazione dei Frame Ethernet

- I pacchetti gestiti dallo switch sono chiamati **frame Ethernet**.
- Lo switch legge unicamente l'indirizzo MAC di destinazione contenuto nel frame.
- L'inoltro avviene in modo efficiente, evitando broadcast non necessari.

14.3 3. La Tabella CAM (Content Addressable Memory)

- **Apprendimento automatico**: lo switch apprende la topologia della LAN osservando da quale porta provengono i frame.
- **Mappatura porte-MAC**: le associazioni tra indirizzi MAC e porte fisiche vengono memorizzate nella **tabella CAM**.
- **Aggiornamento dinamico**: se un frame proveniente dalla sorgente A entra dalla porta P, la coppia (A, P) viene aggiunta alla CAM.

14.4 4. Algoritmo di Smistamento del Traffico

Quando un frame arriva su una porta, lo switch verifica se l'indirizzo MAC di destinazione è presente nella CAM:

- **Indirizzo presente**: il frame viene inoltrato esclusivamente alla porta associata.
- **Indirizzo assente**: il frame viene inviato a tutte le porte, eccetto quella di ingresso (comportamento di flooding).

14.5 5. Funzionalità Avanzate e Sicurezza

- **Filtraggio MAC**: gli switch possono implementare controlli avanzati sugli indirizzi MAC.
- **Rischi di configurazione**: una configurazione errata può esporre parti della LAN verso l'esterno, con potenziali rischi di sicurezza.
- **Simulazione**: è possibile emulare uno switch in ambienti come GNS3 per analizzare il comportamento del traffico e collegare host virtuali.

15 Il Router: Funzioni, Struttura e Ruolo nel Network Layer

Il router è uno dei dispositivi fondamentali, insieme allo switch, senza i quali una rete informatica non potrebbe funzionare. Opera a livello 3 del modello OSI e gestisce gli indirizzi IP, permettendo la comunicazione tra sottoreti differenti.

15.1 1. Funzione Principale e Livello ISO-OSI

- **Ruolo del router**: trasporta i pacchetti al di fuori della sottorete in cui sono stati generati.
- **Livello di rete (Layer 3)**: gestisce gli indirizzi IP e instrada i pacchetti verso reti diverse, a differenza dello switch che opera a livello 2 sugli indirizzi MAC.

15.2 2. Collegamento tra Sottoreti Diverse

Lo switch permette la comunicazione solo tra dispositivi appartenenti alla stessa sottorete. Il router nasce per superare questo limite.

- **Esempio pratico**: reti 192.168.1.0/24 (Amministrazione) e 192.168.2.0/24 (Tecnici) possono comunicare internamente tramite switch, ma non tra loro.
- **Interfacce di rete**: il router collega le sottoreti posizionando un'interfaccia su ciascuna rete, permettendo lo scambio di dati tra segmenti diversi.

15.3 3. Connessione a Internet e Default Gateway

- **Accesso a Internet**: il router collega la rete locale a Internet, composta da reti distinte.
- **Default gateway**: quando un host deve comunicare con un indirizzo IP esterno alla propria sottorete, invia il pacchetto al router configurato come gateway predefinito.

15.4 4. Servizi e Funzionalità Integrate

Nelle reti reali e nei laboratori, i router integrano diverse funzioni essenziali:

- **NAT (Network Address Translation)**: traduce gli indirizzi IP privati in un indirizzo pubblico per la navigazione su Internet.
- **Server DHCP**: molti router assegnano automaticamente indirizzi IP ai client.
- **Tabelle di routing**: le rotte vengono aggiunte automaticamente quando le interfacce si attivano, ma possono essere configurate manualmente (es. `route add -net ...`).
- **Integrazione con firewall**: router e firewall spesso coesistono nello stesso dispositivo. Il firewall applica regole di sicurezza sul traffico in transito.

15.5 5. Sicurezza e Simulazione

- **Rischio di errata configurazione**: una configurazione non corretta può esporre parti della rete interna verso l'esterno.
- **Credenziali di default**: password predefinite non modificate rappresentano un vettore di attacco comune.
- **Simulazione**: è possibile creare e testare topologie con router, switch e host in emulatori come GNS3, utilizzando firmware reali o router Linux (es. OpenWRT).

16 Il Firewall: Struttura, Funzionamento e Ruolo nella Sicurezza di Rete

Il firewall è un dispositivo fondamentale per la protezione delle infrastrutture informatiche. Può essere considerato come un router dotato di funzionalità avanzate di sicurezza, progettato per controllare e filtrare il traffico tra la rete interna e il mondo esterno.

16.1 1. Posizionamento e Livello ISO-OSI

- **Collocazione convenzionale**: situato tra il livello Data Link e il livello Network.
- **Indirizzamento**: analizza sia gli indirizzi MAC (livello 2) sia gli indirizzi IP (livello 3).
- **Firewall perimetrale**: posizionato al confine della rete interna per proteggere LAN e DMZ dalle minacce provenienti dalla WAN.

16.2 2. Filtraggio dei Pacchetti e Criteri delle Regole

La funzione primaria del firewall è il **packet filtering**, ovvero il controllo del traffico in ingresso e in uscita.

Ogni decisione viene presa analizzando tre criteri fondamentali:

1. Indirizzo IP sorgente.
2. Indirizzo IP destinatario.
3. Porta o servizio coinvolto.

Questi elementi permettono di definire le regole che compongono la **security policy** aziendale.

16.3 3. Ordine delle Regole, Cleanup Rule e Default Deny

- **Valutazione sequenziale**: le regole vengono lette dall'alto verso il basso; la prima corrispondente viene applicata.
- **Cleanup rule**: ultima regola della lista, implementa la politica **default deny**. Tutto il traffico non esplicitamente consentito viene bloccato.
- **Fase di test**: in laboratorio si può temporaneamente consentire tutto il traffico per verificare la connettività, applicando poi la cleanup rule finale.

16.4 4. Tipologie e Soluzioni di Mercato

- **Next Generation Firewall (NGFW)**: soluzioni enterprise con funzionalità avanzate (URL filtering, controllo applicativo, VPN, IDS/IPS). Produttori comuni: Fortinet, Checkpoint, Palo Alto, Cisco.
- **Firewall open source**: soluzioni gratuite per ambienti domestici o laboratori (OPNsense, pfSense, OpenWRT).

16.5 5. Fasi di Configurazione Standard

1. Installazione e aggiornamento del firmware o sistema operativo.
2. Configurazione delle interfacce LAN, WAN e DMZ.
3. Scrittura delle security policies.
4. Test del traffico.
5. Attivazione delle funzionalità avanzate.

16.6 6. Impatto nel Penetration Testing

- **Blocco dei tentativi in ingresso**: un firewall ben configurato blocca quasi tutte le connessioni non autorizzate.
- **Asimmetria dei flussi**: il traffico da LAN verso WAN è generalmente consentito, mentre quello inverso è bloccato.
- **Reverse shell**: gli attaccanti sfruttano le connessioni in uscita consentite per agganciare una shell remota verso l'esterno.

17 Fortinet e pfSense: Soluzioni Firewall Enterprise e Open Source

In ambito aziendale e nei laboratori di rete, i firewall rappresentano dispositivi fondamentali per la protezione del perimetro e la gestione del traffico tra LAN, WAN e DMZ. Tra le soluzioni più diffuse troviamo i firewall **Fortinet**, appartenenti alla categoria enterprise, e **pfSense**, soluzione open source basata su FreeBSD.

17.1 Fortinet Firewall

Fortinet rientra nella categoria dei firewall **enterprise**, progettati per ambienti complessi e caratterizzati da funzionalità avanzate.

17.1.1 Fasi di Configurazione Base

Le fasi principali della configurazione iniziale comprendono:

1. Installazione del prodotto.
2. Aggiornamento del firmware o del sistema operativo.
3. Configurazione delle interfacce LAN, WAN e DMZ.
4. Scrittura delle security policies.
5. Test del traffico di rete.
6. Attivazione delle funzionalità avanzate.

17.1.2 Criteri di Filtraggio e Gestione delle Regole

Il firewall valuta i pacchetti in transito sulla base di tre criteri fondamentali:

- Indirizzo IP sorgente.
- Indirizzo IP destinatario.
- Porta o servizio coinvolto.

Nella definizione delle security policies:

- **L'ordine delle regole è determinante**: le regole vengono valutate dall'alto verso il basso.
- **Cleanup rule**: ultima regola del firewall, applica la politica **default deny**, bloccando tutto il traffico non autorizzato.
- **Fase iniziale**: è consigliabile impostare temporaneamente una regola che consenta tutto il traffico per verificare la connettività.

17.2 pfSense

pfSense è un firewall **free e open source** basato su FreeBSD. A differenza delle soluzioni enterprise commerciali, pfSense è destinato principalmente ad ambienti privati, domestici o di laboratorio.

Pur essendo gratuito, mette a disposizione gli strumenti essenziali per:

- gestione del traffico di rete;
- configurazione delle interfacce LAN, WAN e DMZ;
- definizione delle security policies;
- protezione del perimetro di rete.

18 M4 Lab: Progettazione e Gestione del Laboratorio Virtuale di Pentesting

Il modulo M4 Lab, denominato "The Laboratory", è dedicato alla progettazione, configurazione e gestione dell'ambiente di laboratorio virtuale utilizzato per eseguire in sicurezza tutte le esercitazioni pratiche di penetration testing.

18.1 1. Introduzione al Laboratorio e Concetti di Virtualizzazione

- **Scopo del laboratorio**: creare un ambiente isolato e protetto per simulare attacchi informatici ed esercitarsi in modalità learning by doing.
- **Concetto di virtualizzazione**: eseguire più macchine virtuali e sistemi operativi sullo stesso computer fisico, limitati dalle risorse hardware disponibili (CPU, RAM, disco).
- **Terminologia**: distinzione tra **Host** (sistema operativo reale) e **Guest** (sistema operativo eseguito nella VM).
- **Procedura di creazione**: installazione dell'hypervisor, download delle immagini ISO, configurazione dell'hardware virtuale e installazione del sistema operativo guest.

18.2 2. Hypervisor e Sistemi Operativi Utilizzati

- **Hypervisor**: software che permette di creare e gestire macchine virtuali.
- **Tipologie presentate**:
  - VMware Workstation (proprietario, trial 30 giorni) e VMware Player (proprietario, gratuito).
  - Oracle VirtualBox (gratuito e open source).
  - QEMU (gratuito e open source).
- **Focus del corso**: VirtualBox, QEMU e Docker (Linux Containers - LXC).
- **Sistemi operativi utilizzati**:
  - Kali Linux come macchina d'attacco.
  - Windows 7 / Windows 10 come macchine bersaglio.
- **Gestione delle risorse**: attenzione alla RAM allocata per evitare saturazione dell'host.

18.3 3. Gestione delle Reti Virtuali in VirtualBox

VirtualBox permette di configurare diverse modalità di rete:

- **Not attached**: interfaccia attiva ma isolata.
- **NAT**: servizio interno di NAT e DHCP; la VM accede alla rete esterna ma non comunica con host o altre VM.
- **NAT network**: NAT condiviso tra più VM, con comunicazione tra guest.
- **Bridged**: la VM si collega direttamente alla rete fisica dell'host.
- **Internal network**: rete isolata tra VM tramite switch virtuale.
- **Host-only**: rete interna tra VM e host tramite adattatore virtuale dedicato.

18.4 4. Virtualizzazione vs Containerizzazione

- **Integrazione in GNS3**: supporto per VirtualBox, QEMU e VMware.
- **Limiti dei multi-hypervisor**: elevato consumo di risorse e possibili incompatibilità.
- **Vantaggi dei container Docker**: processi isolati che condividono il kernel dell'host, con maggiore efficienza rispetto alle VM tradizionali.

18.5 5. Architettura del Laboratorio di Pentesting

Il laboratorio virtuale è strutturato come segue:

- **Segmento Inside (LAN)**: rete interna protetta, con assegnazione IP tramite DHCP.
- **Firewall perimetrale (OPNsense)**: gestisce il traffico tra le zone:
  - Inside → Outside (consentito).
  - DMZ ↔ Outside (regolato).
  - Inside ↔ DMZ (consentito per la gestione).
- Creazione di Virtual IP per esporre server in DMZ.
- **DMZ**: ospita i server target (es. WackoPicko) con IP statici o DHCP.
- **Nodo NAT**: fornisce connettività verso host e Internet.
- **Macchina attaccante**:
  - Opzione 1: VM Kali Linux sulla rete Outside.
  - Opzione 2 (consigliata): utilizzare direttamente l'host tramite il nodo NAT.

19 Classificazione dei Test di Penetration Testing: Black Box, White Box e Grey Box

Nell'ambito dell'ethical hacking e del penetration testing, la classificazione dei test dipende dal livello di conoscenza preliminare che il tester possiede riguardo al bersaglio. Le metodologie principali sono tre: **Black Box**, **White Box** e **Grey Box**.

19.1 1. Black Box Testing (Test a Scatola Nera)

- **Livello di conoscenza**: il tester non possiede alcuna informazione sull'infrastruttura o sui sistemi da analizzare.
- **Informazioni fornite**: spesso viene comunicato solo un dato pubblico, come l'indirizzo del sito web aziendale.
- **Contesto operativo**: simula il comportamento di un attaccante esterno reale.
- **Information Gathering**: la prima fase consiste in una raccolta approfondita di informazioni tramite fonti aperte (OSINT).

19.2 2. White Box Testing (Test a Scatola Bianca)

- **Livello di conoscenza**: il tester dispone di tutte le informazioni dettagliate sull'ambiente da esaminare.
- **Collaborazione**: il lavoro avviene a stretto contatto con figure interne come i security engineer.
- **Contesto operativo**: permette di analizzare architettura interna, logica dei servizi e configurazioni senza dedicare tempo alla ricognizione esterna.

19.3 3. Grey Box Testing (Test a Scatola Grigia)

- **Livello di conoscenza**: rappresenta una via di mezzo tra Black Box e White Box; vengono fornite informazioni parziali.
- **Esempi di informazioni**: credenziali con privilegi base, mappa parziale della rete o documentazione limitata.
- **Contesto operativo**: è la metodologia più utilizzata dai penetration tester professionisti.
- **Realismo**: simula scenari realistici, come attacchi da parte di utenti interni o attaccanti che hanno già ottenuto un primo punto di accesso.
- **Approccio cautelativo**: sovrastimare le capacità iniziali dell'attaccante risulta più sicuro per la protezione aziendale.

20 M5: Information Gathering nel Penetration Testing

Il modulo M5 è interamente dedicato alla fase di **Information Gathering**, ovvero la ricognizione e raccolta di informazioni preliminari sul bersaglio. Questa fase rappresenta il primo step fondamentale di un penetration test, soprattutto quando si opera in modalità **Black Box** senza alcuna conoscenza preventiva del target.

20.1 1. Introduzione e Metodologia OSINT

- **Inizio del Black Box Testing**: il tester deve raccogliere informazioni partendo da fonti aperte di pubblico dominio (OSINT).
- **Dipendenza dal target**: il tipo di dati da cercare varia in base al settore dell'azienda bersaglio.
- Esempi: ricerca di dettagli su dipendenti, fornitori, relazioni aziendali e dati societari.

20.2 2. Google Hacking e Google Dorks

Il modulo approfondisce l'uso avanzato dei motori di ricerca per individuare informazioni non immediatamente visibili.

- **Operatori di ricerca**:
  - `site:`
  - `allintitle:`
  - `inurl:`
  - `filetype:`
- **Directory listings**: query come `intitle:index.of` per individuare cartelle esposte.
- **Query combinate**: `inurl:admin`, `inurl:backup`, `inurl:admin filetype:xls`.
- **Google Hacking Database**: raccolta di dork pronti all'uso su Exploit-DB.

20.3 3. Analisi Storica e Pagine in Cache

- **Google Cache**: recupero delle copie memorizzate tramite `cache:www.website.com`.
- **CachedView**: servizi online per visualizzare pagine archiviate.
- **Wayback Machine**: analisi storica delle revisioni del sito tramite `archive.org/web/`.

20.4 4. Social Media e Annunci di Lavoro

- **SOCMINT**: analisi dei profili social dell'azienda e dei dipendenti.
- **Job listings**: le offerte di lavoro rivelano tecnologie, versioni software e strumenti utilizzati internamente.

20.5 5. Estrazione dei Metadati

- Analisi dei documenti trovati online per estrarre metadati (autore, software, percorsi interni).

20.6 6. Query DNS e Laboratorio OPNsense

- **Risoluzione nomi**: comandi `nslookup` e `dig` per interrogare record DNS.
- **Configurazione in lab**: attivazione del server DNS su OPNsense tramite Unbound DNS Override.

20.7 7. DNS Zone Transfer (AXFR)

- **Zone transfer**: richiesta al server DNS della lista completa dei record.
- **Comando**: `dig @IP_DNS domain AXFR`.
- **Esito**: elenco dei sottodomini oppure errore `Transfer failed`.
- **Rischi**: fuga di informazioni e possibili attacchi DoS.

20.8 8. Strumenti di Automazione

- **Maltego**: costruzione di un albero di conoscenza tramite trasformazioni.
- **Recon-ng**: piattaforma di ricognizione automatizzata.

20.9 9. Ricerca di Dispositivi con Shodan

- **Shodan**: motore di ricerca per dispositivi esposti su Internet.
- **Esempio di query**: `scada port:"80"` per individuare dispositivi SCADA con server web attivo.

21 M6: Network Scanning

Il pacco di slide M6 (`M6 scan.pptx.pdf`) descrive la fase di *Network Scanning*, segnando il passaggio fondamentale dalla ricognizione passiva all'interazione diretta con il bersaglio, con il conseguente rischio di essere rilevati dai sistemi di sicurezza.

21.1 Scansione a Livello 2 (Data Link Layer)

Nella rete locale (LAN), la scoperta degli host attivi avviene a livello 2 basandosi sugli indirizzi MAC e sul protocollo ARP.

- **Scansione Locale ARP:** Identificazione delle macchine attive all'interno del medesimo dominio di broadcast tramite richieste ARP.
- **Uso di Arping:** Esecuzione del comando `arping` per inviare richieste ARP dirette a un target (ad esempio verso il firewall OPNsense):

  ```
  arping 192.168.122.200 -c 4 -I virbr0
  ```

- **Ispezione con Wireshark:** Il traffico ARP generato viene catturato e analizzato in tempo reale tramite Wireshark per confermare la risposta degli host.

21.2 Scansione a Livello 3 (Network Layer) e Nmap

Fuori dalla LAN locale si passa all'indirizzamento IP (livello 3). **Nmap** viene presentato come il tool di network scanning più affidabile e versatile, in grado di coprire molteplici livelli e fasi di analisi.

21.2.1 Host Discovery / Ping Sweep

Tramite l'opzione `-sn`, Nmap esegue una *Host Discovery* (ping sweep basato principalmente su ICMP) per identificare quali IP sono attivi in un intervallo di rete senza effettuare la scansione delle porte.

21.2.2 Le 11 Fasi di Nmap

Il modulo elenca il flusso sequenziale gestito da Nmap durante un'analisi:

1. Risoluzione dei nomi
2. Fase pre-scan dello script engine (NSE)
3. Host discovery / Ping scanning
4. Enumerazione dei target
5. Risoluzione DNS inversa
6. Scansione di porte o protocolli
7. Rilevamento della versione dei servizi
8. Fingerprinting del sistema operativo (OS)
9. Traceroute
10. Esecuzione degli script NSE (`portrule`/`hostrule`)
11. Fase post-scan NSE

21.3 Struttura dei Pacchetti e Flag TCP

- **Header TCP e UDP:** Analisi dei campi che compongono le intestazioni dei pacchetti a livello di trasporto.
- **Flag di Controllo TCP:** Per gestire e verificare le connessioni, TCP utilizza 6 flag principali: SYN (sincronizzazione iniziale), ACK (riscontro), RST (reset della connessione), FIN, PSH e URG.
- **Three-Way Handshake:** Scambio standard per stabilire una connessione TCP (SYN $\rightarrow$ SYN/ACK $\rightarrow$ ACK), con ispezione visiva dell'attivazione dei singoli bit dei flag all'interno di Wireshark.

21.4 Scansioni a Livello 4 (Transport Layer – Porte e Servizi)

Il modulo approfondisce le principali modalità di scansione delle porte tramite Nmap e la loro risposta nei tracciati PCAP:

TCP Connect Scan (`nmap -sT`): Completa l'intero Three-way Handshake instaurando una connessione TCP reale con il servizio target. È una scansione molto rumorosa (*noisy*) e facilmente tracciabile o registrata nei log di sistema.

SYN Stealth Scan (`nmap -sS`): Nota come scansione *half-open* (completata solo a metà). L'attaccante invia un pacchetto con flag SYN; se la porta è aperta, il target risponde con SYN/ACK. A quel punto l'attaccante invia immediatamente un pacchetto con flag RST per interrompere la connessione prima che venga stabilita del tutto.

UDP Scan (`nmap -sU`): Utilizzata per i servizi basati su UDP (protocollo non orientato alla connessione, come il DNS sulla porta 53). Poiché UDP non prevede un handshake, se la porta è aperta si riceve una risposta applicativa specifica (o nessuna risposta). Se la porta è chiusa, la macchina bersaglio restituisce solitamente un messaggio di errore ICMP di tipo *Destination Unreachable / Port Unreachable*.

22 M7: Banner Grabbing e OS Fingerprinting

Il pacco di slide M7 (`M7 banner.pptx.pdf`) illustra le tecniche di **Banner Grabbing** e **OS Fingerprinting**. Questa fase si colloca immediatamente dopo la scansione delle porte e serve a identificare la tipologia e la versione esatta dei servizi in esecuzione, oltre al sistema operativo installato sull'host target. Tali informazioni sono indispensabili per le successive fasi di *Vulnerability Assessment* ed *Exploitation*.

22.1 Banner Grabbing dei Servizi (HTTP e FTP)

L'obiettivo principale del banner grabbing è estrarre la stringa d'intestazione (*banner*) inviata dai server alla connessione, così da ricavarne marca, versione e dettagli applicativi.

22.1.1 Interazione con Web Server (HTTP)

- **Telnet:** Permette di aprire una connessione diretta sulla porta HTTP (es. porta 80) e inviare manualmente comandi HTTP per restituire gli header del server:

```
telnet <IP> 80
GET / HTTP/1.1
Host: <IP>
```

Un esempio di risposta può mostrare header come: `Server: Apache/2.2.8 (Ubuntu) PHP/5.2.4`.

- **Netcat (`nc`):** Definito il "coltellino svizzero della rete", consente di eseguire la medesima operazione di banner grabbing inviando la richiesta direttamente da riga di comando.

22.1.2 Interazione con Server FTP

- **Netcat e Telnet:** Collegandosi alla porta 21 (es. `nc <IP> 21` oppure `telnet <IP> 21`), il server FTP risponde immediatamente inviando il banner iniziale (es. `220 (vsFTPd 2.3.4)`).
- **Nmap (`-sV`):** Automatizza la scansione delle versioni interrogando le porte specificate:

  nmap −sV −p 21 <IP>

- **Metasploit Framework:** Utilizza il modulo ausiliario `auxiliary/scanner/ftp/ftp_version`:

```
msfconsole
use auxiliary/scanner/ftp/ftp_version
set RHOSTS <IP>
run
```

22.1.3 Offuscamento del Banner (Banner Obfuscation)

Un amministratore di sistema può mascherare o alterare il banner per proteggere la macchina dai rilevamenti automatici (ad esempio decommentando e modificando il parametro `ftpd_banner` all'interno del file `/etc/vsftpd.conf`).

In questi casi, una scansione automatica di Nmap rileverà la porta come aperta (`21/tcp open ftp?`), ma non sarà in grado di determinare la versione esatta del servizio basandosi unicamente sulla risposta standard.

22.2 Nmap Service Probes

Per superare le limitazioni imposte dall'offuscamento dei banner, Nmap impiega un meccanismo interno basato su **probes** (sonde di verifica):

- Nmap invia sequenze di messaggi specifici studiati per sollecitare una risposta precisa da parte del servizio attivo sulla porta.
- Il parsing dei dati ricevuti avviene tramite espressioni regolari (*regex*) e gruppi di cattura definiti all'interno del file di configurazione `nmap-service-probes`.

Listing 1: Esempio di regola regex utilizzata da Nmap per l'identificazione di vsFTPd

```
match ftp m|^220 \(vsFTPd ([-.\w]+)\)\r\n$| p/vsftpd/ v/$1/ o/Unix/
```

22.3 Operating System Detection (OS Fingerprinting)

Oltre all'identificazione dei singoli servizi, il modulo tratta l'analisi del sistema operativo complessivo della macchina target, suddivisa in due metodologie:

22.3.1 Modalità Attiva (Active Mode)

Consiste nell'invio diretto di pacchetti e sonde di verifica verso la macchina bersaglio, analizzando le risposte ottenute su porte sia aperte che chiuse:

- **Nmap (`nmap -O -v <IP>`):** Analizza le risposte TCP/IP (es. gestione delle opzioni TCP, finestra di ricezione, risposta ai pacchetti malformati) per determinare la famiglia dell'OS e la versione del kernel Linux/Windows.
- **XPROBE2 (`xprobe2 <IP>`):** Strumento specializzato che invia sonde ICMP e TCP e restituisce una lista di sistemi operativi candidati associati a una percentuale di probabilità (es. *Linux Kernel 2.6.11 con probabilità al 95%*).

22.3.2 Modalità Passiva (Passive Mode)

Analizza il traffico di rete in transito senza inviare alcun pacchetto al bersaglio, garantendo la massima invisibilità nei confronti di firewall e sistemi IDS/IPS:

- **Principio di funzionamento:** Sfrutta le differenze nei valori di default impiegati dalle stack di rete dei vari sistemi operativi (ad esempio il valore del **TTL** predefinito, tipicamente pari a `64` su sistemi Linux e `128` su sistemi Windows, o la dimensione della *TCP Window Size*).
- **P0f (`p0f`):** Principale tool per l'OS fingerprinting passivo. Può operare in tempo reale su un'interfaccia di rete oppure analizzare file di cattura pregressi (`.pcap`):

```
# Analisi in tempo reale su interfaccia
sudo p0f -i eth0

# Analisi di un file di cattura PCAP
p0f -r capture.pcap
```

23 M8: Enumeration

L'**Enumeration** (Enumerazione) è la fase del penetration test in cui il tester interagisce direttamente con i servizi identificati durante la scansione per estrarre il maggior numero possibile di informazioni sui sistemi e sugli asset di rete. A differenza dell'Information Gathering, che si basa principalmente su fonti esterne, l'enumerazione sfrutta le caratteristiche specifiche dei servizi esposti dal target.

Tool	Ambito di Utilizzo	Modalità
`telnet` / `nc`	Banner Grabbing manuale (HTTP/FTP)	Attiva
`nmap -sV`	Service & Version Detection (Probes)	Attiva
`nmap -O`	OS Detection tramite analisi risposte TCP/IP	Attiva
`xprobe2`	OS Fingerprinting basato su punteggio probabilistico	Attiva
`p0f`	OS Fingerprinting passivo tramite analisi traffico/PCAP	Passiva

Tabella 1: Panoramica degli strumenti di Banner Grabbing e OS Detection

23.1 1. Concetti Fondamentali e Servizi Target

L'enumerazione viene eseguita sui servizi individuati come aperti durante le fasi precedenti del test.

I principali servizi soggetti a tecniche di enumerazione sono:

- **SMTP** (TCP 25).
- **DNS** (TCP/UDP 53).
- **SNMP** (UDP 161).
- **NetBIOS / SAMBA** (UDP 137–138, TCP 139 e 445).

23.2 2. Enumerazione SAMBA e NetBIOS

Il protocollo NetBIOS opera a livello Session del modello ISO/OSI e permette di individuare risorse condivise all'interno della rete.

Tra le informazioni ottenibili figurano:

- hostname;
- utenti;
- domini e workgroup;
- stampanti condivise;
- cartelle e risorse di rete.

23.2.1 Nmap e NSE Scripts

Una prima verifica consiste nel controllare l'apertura delle porte TCP 139 e 445.

Nmap mette a disposizione diversi script NSE dedicati all'enumerazione SMB:

- `smb-enum-users.nse`;
- `smb-enum-shares.nse`;
- `smb-enum-domains.nse`.

Questi script consentono di identificare utenti, condivisioni e informazioni sul dominio.

23.2.2 rpcclient

`rpcclient` è un client SAMBA che permette di interrogare i servizi SMB tramite una console interattiva.

Alcuni comandi utili sono:

- `querydominfo` per ottenere informazioni sul dominio;
- `enumdomusers` per elencare gli utenti;
- `queryuser` per visualizzare i dettagli di uno specifico account.

23.2.3 enum4linux

Gli strumenti `enum4linux` ed `enum4linux-ng` automatizzano il processo di raccolta delle informazioni, consentendo di individuare rapidamente:

- utenti;
- condivisioni;
- stampanti;
- versione di SAMBA installata.

23.3 3. Enumerazione SMTP

SMTP (Simple Mail Transfer Protocol) è il protocollo impiegato per l'invio delle email e utilizza normalmente la porta TCP 25.

23.3.1 Comandi SMTP Tramite Telnet

Una sessione SMTP può essere testata mediante connessione Telnet e l'utilizzo dei seguenti comandi:

- `HELO`: identificazione del client;
- `DATA`: avvio del trasferimento del messaggio;
- `VRFY`: verifica dell'esistenza di un utente;
- `QUIT`: chiusura della connessione.

Il comando `VRFY` è particolarmente utile durante l'enumerazione:

- risposta `252`: utente esistente;
- risposta `550`: utente inesistente.

23.3.2 Enumerazione Automatizzata

Le verifiche possono essere eseguite su intere wordlist di utenti potenziali ottenute tramite OSINT o repository pubblici.

Metasploit mette a disposizione il modulo:

```
auxiliary/scanner/smtp/smtp_enum
```

che consente di automatizzare la verifica massiva degli account.

23.4 4. Enumerazione Apache UserDir

Il modulo Apache `mod_userdir` consente l'accesso alle directory personali degli utenti mediante URL del tipo:

```
http://www.sito.com/~utente
```

L'analisi delle risposte HTTP permette di inferire l'esistenza degli utenti:

- `403 Forbidden`: l'utente esiste ma la directory non è accessibile;
- `404 Not Found`: l'utente non esiste.

Nmap fornisce lo script:

```
http-userdir-enum
```

per automatizzare questo processo.

23.5 5. Enumerazione Tramite Credenziali di Default

Molti dispositivi di rete vengono distribuiti con credenziali predefinite che gli amministratori dimenticano di modificare.

Tra i dispositivi maggiormente interessati:

- router;
- switch;
- firewall;
- apparati IoT.

Banche dati pubbliche consentono di reperire username e password di default conoscendo marca e modello del dispositivo.

Un esempio storico è rappresentato dalla botnet Mirai, che ha compromesso un elevato numero di dispositivi IoT sfruttando un elenco molto ridotto di credenziali predefinite.

23.6 6. Enumerazione Tramite Vulnerabilità SQL Injection

L'enumerazione può essere eseguita anche sfruttando vulnerabilità applicative.

23.6.1 In-Band SQL Injection

Attraverso vulnerabilità SQL Injection è possibile alterare le query eseguite dal database e ottenere informazioni aggiuntive.

Ad esempio, tramite l'operatore UNION possono essere recuperati l'utente del database e la versione del DBMS:

```
' UNION SELECT user(), version() #
```

23.6.2 Blind SQL Injection

Quando l'applicazione non restituisce direttamente le informazioni richieste, è possibile inferirle osservando il comportamento del sistema.

L'attaccante procede attraverso:

1. identificazione della risposta associata alle condizioni TRUE e FALSE;
2. interrogazione delle tabelle di sistema;
3. ricostruzione progressiva delle informazioni.

23.6.3 Interrogazione dello Schema

Una tecnica comune consiste nell'interrogare le tabelle dello schema informativo:

- `INFORMATION_SCHEMA.TABLES`;
- `INFORMATION_SCHEMA.COLUMNS`.

In questo modo è possibile verificare l'esistenza di specifiche tabelle e colonne.

23.6.4 Ricerca Binaria

Per estrarre stringhe lunghe in modo efficiente si utilizza una ricerca binaria sul valore ASCII dei caratteri.

La logica consiste nel verificare se:

```
ORD(MID(stringa,posizione,1)) <= ORD('m')
```

Ripetendo il procedimento carattere per carattere è possibile ricostruire progressivamente informazioni sensibili come nomi utente, nomi di tabelle e altri dati presenti nel database.

24 M9: Vulnerability Assessment

Il **Vulnerability Assessment** rappresenta la fase del penetration test dedicata all'identificazione, analisi e validazione delle vulnerabilità presenti nei sistemi bersaglio. Dopo aver completato le attività di scanning ed enumeration, il tester passa alla ricerca sistematica delle falle di sicurezza che potrebbero essere sfruttate da un attaccante.

24.1 Vulnerability Assessment e Penetration Testing

L'obiettivo principale di un Vulnerability Assessment è il rilevamento delle vulnerabilità presenti in un sistema.

È opportuno distinguere questa attività dal Penetration Testing:

- **Vulnerability Assessment**: identifica e documenta le vulnerabilità.
- **Penetration Testing**: comprende anche le successive fasi di exploitation e post-exploitation.

24.2 Il Ruolo del Proof-of-Concept (PoC)

La semplice identificazione della versione di un software non è sufficiente per confermare la presenza di una vulnerabilità, poiché un sistema potrebbe essere stato aggiornato o patchato mantenendo invariati banner e informazioni di versione.

Per questo motivo si utilizza un **Proof-of-Concept (PoC)**, ovvero una dimostrazione pratica e innocua della vulnerabilità.

Un PoC deve:

- dimostrare concretamente la presenza della falla;
- non causare danni al sistema;
- non compromettere la disponibilità dei servizi.

24.3 Metodologie di Individuazione delle Vulnerabilità

Escludendo le vulnerabilità zero-day, le falle possono essere individuate attraverso tre approcci principali:

1. utilizzo di vulnerability scanner automatici;
2. consultazione manuale di database di vulnerabilità;
3. analisi basata sulle competenze di dominio del tester.

24.4 Vulnerability Scanner Automatici

Tra gli strumenti maggiormente utilizzati figurano:

- Nessus;
- Nexpose;
- OpenVAS;
- Greenbone Security Assistant.

Gli scanner automatici consentono di identificare rapidamente vulnerabilità note, ma presentano alcune limitazioni:

- difficoltà nella rilevazione di casi particolari (corner cases);
- scarsa efficacia verso software sviluppato su misura;
- incapacità di comprendere la logica applicativa.

Esempi pratici mostrano come una piattaforma volutamente vulnerabile possa presentare numerose vulnerabilità critiche pur venendo classificata dagli scanner con un numero limitato di segnalazioni.

24.5 Quality of Detection (QoD)

Gli scanner possono associare alle vulnerabilità rilevate un livello di affidabilità denominato **Quality of Detection (QoD)**.

Un QoD ridotto indica che lo strumento non è riuscito a verificare completamente la vulnerabilità e che è necessaria una conferma manuale.

Per validare la presenza della falla il tester può ricercare effetti collaterali osservabili, ad esempio:

- connessioni di ritorno verso un listener controllato;
- variazioni nei tempi di risposta;
- comportamenti anomali verificabili dall'esterno.

24.6 Vulnerabilità Applicative e Software Custom

Le vulnerabilità applicative risultano particolarmente difficili da individuare mediante strumenti automatici.

Tra le categorie principali rientrano:

- Remote Command Execution (RCE);
- SQL Injection (SQLi);
- Cross-Site Scripting (XSS).

L'analisi di tali vulnerabilità richiede frequentemente verifiche manuali e una comprensione approfondita della logica dell'applicazione.

25 Cross-Site Scripting (XSS)

La **Cross-Site Scripting (XSS)** è una vulnerabilità web classificata come **CWE-79**. Essa deriva da una validazione o sanitizzazione insufficiente dell'input fornito dagli utenti.

La vulnerabilità permette l'esecuzione di codice JavaScript arbitrario nel browser della vittima.

Un classico Proof-of-Concept consiste nell'esecuzione di un semplice script che genera un messaggio nel browser.

25.1 Tipologie di XSS

25.1.1 Reflected XSS

L'input inviato dall'utente viene immediatamente riflesso nella risposta HTTP restituita dal server.

È tipica dei campi di ricerca e dei parametri URL.

25.1.2 Stored XSS

L'input viene memorizzato dall'applicazione (ad esempio in un database) e successivamente presentato a tutti gli utenti che visitano la pagina.

Questa variante è considerata la più pericolosa poiché produce effetti persistenti.

25.2 Tainted Flows e Contesti HTML

Un input controllato dall'utente prende il nome di **tainted input**.

Quando tale input raggiunge una pagina HTML senza adeguata sanitizzazione si genera un **tainted flow**.

L'input può essere inserito in differenti contesti:

- corpo del documento HTML;
- attributi HTML;
- codice JavaScript;
- CSS;
- URL.

Per individuare un tainted flow durante le attività di testing è comune utilizzare stringhe facilmente riconoscibili e verificarne la presenza nella pagina generata.

25.3 Bypass della Sanitizzazione

I filtri implementati dagli sviluppatori possono risultare incompleti.

Quando specifici tag vengono bloccati, l'esecuzione di codice può essere ottenuta sfruttando:

- tag HTML alternativi;
- event handler;
- contesti di rendering differenti.

Questo rende l'identificazione automatica delle vulnerabilità XSS particolarmente complessa.

25.4 Client-Side Exploitation e BeEF

Le vulnerabilità XSS costituiscono uno dei principali vettori di attacco client-side.

Un browser vulnerabile può essere agganciato a framework di analisi e simulazione come BeEF attraverso il caricamento di codice JavaScript controllato dall'attaccante.

Una volta eseguito il codice nel browser, è possibile:

- raccogliere informazioni sul client;
- interagire con il DOM;
- eseguire codice JavaScript arbitrario;
- analizzare la rete locale raggiungibile dal browser.

26 SQL Injection (SQLi)

La **SQL Injection** è una vulnerabilità causata dall'inserimento non sicuro dell'input dell'utente all'interno di query SQL.

L'attaccante può modificare il comportamento della query originaria ed eseguire operazioni non previste dagli sviluppatori.

26.1 Tecniche di Rilevamento

Durante il Vulnerability Assessment vengono utilizzati PoC innocui per verificare la presenza della vulnerabilità.

Le verifiche principali includono:

- **Parse Error**: generazione di errori sintattici nella query.
- **Query Forging**: modifica della logica booleana della query.

L'osservazione di errori o comportamenti anomali costituisce un forte indicatore della presenza della vulnerabilità.

26.2 In-Band SQL Injection

Questa tecnica si applica quando l'applicazione restituisce direttamente i risultati della query.

L'attaccante può sfruttare l'operatore `UNION` per combinare i risultati della query originale con quelli della query malevola.

Tra le informazioni che possono essere recuperate figurano:

- versione del DBMS;
- database corrente;
- utente del database;
- contenuto delle tabelle.

26.3 Blind SQL Injection

Quando l'applicazione non restituisce dati direttamente all'utente si ricorre alla **Blind SQL Injection**.

L'attaccante deduce le informazioni osservando il comportamento dell'applicazione.

Il procedimento segue generalmente le seguenti fasi:

1. identificazione delle condizioni TRUE e FALSE;
2. interrogazione dello schema del database;
3. estrazione progressiva dei dati.

26.4 Interrogazione dello Schema

Le informazioni strutturali del database possono essere recuperate interrogando le tabelle di sistema.

Ad esempio:

- INFORMATION_SCHEMA.TABLES;
- INFORMATION_SCHEMA.COLUMNS.

Queste consentono di individuare database, tabelle e colonne disponibili.

26.5 Ricerca Binaria e Time-Based SQLi

Poiché una Blind SQL Injection restituisce normalmente una sola informazione booleana per ogni richiesta, le stringhe vengono ricostruite carattere per carattere.

Per ottimizzare il processo viene utilizzata una ricerca binaria sui codici ASCII dei caratteri.

Quando non sono disponibili differenze evidenti nelle risposte dell'applicazione, il tester può ricorrere a tecniche **Time-Based** che sfruttano ritardi temporali introdotti dal database.

26.6 Funzioni SQL Utilizzate nei Test

Tra le funzioni maggiormente utilizzate durante le attività di verifica figurano:

- `MID()`;
- `ORD()`;
- `ASCII()`;
- `SLEEP()`;
- `BENCHMARK()`;
- `LIMIT`;
- `LIKE`;
- `CONCAT()`;
- `NULL`.

26.7 DBMS e Banner Grabbing

Ogni DBMS implementa un proprio dialetto SQL.

Prima di procedere con l'analisi è importante identificare il database utilizzato attraverso attività di banner grabbing e fingerprinting, poiché le funzioni disponibili variano tra MySQL, Microsoft SQL Server, PostgreSQL e Oracle.

26.8 Automazione con SQLMap

SQLMap rappresenta uno dei principali strumenti per l'automazione delle attività di verifica delle SQL Injection.

Tra le funzionalità principali figurano:

- identificazione automatica della vulnerabilità;
- rilevamento del DBMS utilizzato;
- enumerazione di database, tabelle e colonne;
- estrazione controllata delle informazioni.

Nonostante l'elevato grado di automazione, i risultati ottenuti devono sempre essere verificati e interpretati dal penetration tester.

27 M10: Exploitation

L'**Exploitation** rappresenta la fase del penetration test in cui le vulnerabilità precedentemente identificate vengono effettivamente sfruttate per valutare il livello reale di esposizione del sistema bersaglio. Lo scopo di questa fase non è soltanto dimostrare l'esistenza di una vulnerabilità, ma comprendere quali impatti concreti essa possa avere sulla sicurezza dell'infrastruttura.

27.1 Dalla Vulnerability Assessment all'Exploitation

Durante la fase di Vulnerability Assessment vengono utilizzati Proof-of-Concept (PoC) innocui per verificare la presenza di una vulnerabilità.

L'Exploitation si differenzia perché mira a valutare:

- il livello di compromissione ottenibile;
- l'impatto effettivo sull'infrastruttura;
- le possibilità di accesso ai sistemi;
- i rischi associati alla vulnerabilità identificata.

Mentre un PoC ha esclusivamente lo scopo di confermare l'esistenza della falla, un exploit completo può consentire effetti concreti quali l'accesso ai sistemi, l'acquisizione di dati o l'esecuzione di operazioni non autorizzate.

27.2 Exploit, Attacchi e Decision Trees

27.2.1 Exploit

Un **exploit** può essere definito come una sequenza di operazioni che sfrutta una vulnerabilità per ottenere uno specifico risultato.

Tra gli effetti ottenibili rientrano:

- accesso non autorizzato;
- esecuzione di codice;
- escalation dei privilegi;
- accesso a dati riservati.

27.2.2 Attacco

Un attacco è tipicamente costituito da una catena di exploit concatenati finalizzati al raggiungimento di un obiettivo più ampio.

Durante tale processo possono verificarsi:

- movimenti laterali tra sistemi differenti;
- escalation di privilegi;
- accesso progressivo a risorse sempre più sensibili.

27.2.3 Decision Trees

Poiché il penetration tester opera spesso in modalità Black Box, il processo di attacco segue una logica ad albero decisionale.

Ogni azione successiva dipende dai risultati ottenuti negli step precedenti:

- individuazione della vulnerabilità;
- verifica della sfruttabilità;
- scelta della tecnica di attacco più appropriata;
- valutazione dei risultati ottenuti.

27.3 Controllo Remoto e Persistenza

Uno degli obiettivi principali dell'exploitation consiste nell'ottenere un canale di comunicazione stabile con il sistema compromesso.

Una volta stabilito tale canale, l'attaccante può interagire direttamente con il sistema operativo senza dipendere dalla vulnerabilità iniziale che ha consentito l'accesso.

Le motivazioni principali includono:

- mantenimento dell'accesso;
- esecuzione di operazioni aggiuntive;
- raccolta di informazioni;
- supporto alle fasi successive del test.

27.4 Client-Side Exploitation

Gli attacchi client-side non prendono di mira direttamente i server ma i dispositivi utilizzati dagli utenti.

Tra i vettori comunemente analizzati durante un penetration test figurano:

- campagne di phishing;
- attacchi di spear phishing;
- documenti contenenti macro;
- siti web compromessi;
- malware fileless;
- contenuti malevoli distribuiti tramite posta elettronica o servizi web.

Un principio fondamentale è quello della **minima interazione**: minore è il numero di azioni richieste alla vittima, maggiore è generalmente l'efficacia dell'attacco.

27.5 Framework e Strumenti di Analisi

27.5.1 Browser Exploitation Framework

Tra gli strumenti analizzati durante il corso figura **BeEF (Browser Exploitation Framework)**, utilizzato per lo studio delle vulnerabilità che coinvolgono il browser web.

Le sue funzionalità comprendono:

- raccolta di informazioni sul client;
- analisi del browser;
- studio degli attacchi client-side;
- simulazione di tecniche basate su JavaScript.

27.5.2 Metasploit Framework

Metasploit rappresenta una delle piattaforme più diffuse per l'automazione delle attività di vulnerability validation ed exploitation.

Il framework permette di:

- organizzare exploit e payload;
- gestire sessioni remote;
- automatizzare verifiche di sicurezza;
- simulare diversi scenari di compromissione.

27.5.3 Meterpreter

Meterpreter è un payload avanzato integrato all'interno di Metasploit.

Le sue caratteristiche principali includono:

- esecuzione prevalentemente in memoria;
- supporto multipiattaforma;
- estendibilità tramite moduli;
- riduzione delle tracce lasciate sul filesystem.

27.6 Laboratori e Simulazioni

Il modulo prevede l'utilizzo di ambienti controllati per simulare scenari di compromissione.

Tra gli elementi utilizzati nel laboratorio figurano:

- sistemi Linux;

- sistemi Windows;
- macchine Android virtualizzate;
- applicazioni web vulnerabili;
- infrastrutture emulate tramite GNS3.

L'obiettivo delle esercitazioni è comprendere il comportamento delle vulnerabilità studiate nelle fasi precedenti e valutare in modo concreto il loro impatto sulla sicurezza dell'infrastruttura.

27.7 Considerazioni Finali

L'Exploitation rappresenta il punto di collegamento tra la fase di identificazione delle vulnerabilità e le successive attività di post-exploitation. Attraverso lo sfruttamento controllato delle falle individuate, il penetration tester è in grado di valutare il rischio reale associato a ciascuna vulnerabilità e di produrre evidenze tecniche utili alla definizione delle attività di remediation.

28 M11: Post-Exploitation

La **Post-Exploitation** comprende tutte le attività svolte dopo aver ottenuto con successo l'accesso iniziale a un sistema bersaglio. In questa fase il penetration tester valuta il reale impatto della compromissione, verifica la possibilità di incrementare i privilegi, raccoglie evidenze e analizza la propagazione dell'attacco all'interno dell'infrastruttura.

28.1 Le Attività Fondamentali della Post-Exploitation

La fase di Post-Exploitation può essere suddivisa nelle seguenti attività principali:

1. Privilege Escalation.
2. Access Maintenance.
3. Data Collection.
4. Internal Network Mapping.
5. Exploitation dei nuovi sistemi individuati.

Queste attività sono strettamente correlate e vengono spesso eseguite in modo iterativo durante un attacco o un penetration test.

28.2 Privilege Escalation

L'accesso iniziale ottenuto tramite una vulnerabilità fornisce frequentemente privilegi limitati. Lo scopo della privilege escalation consiste nell'acquisire privilegi amministrativi o di sistema.

28.2.1 Obiettivi

- **Windows**: ottenere privilegi Administrator o SYSTEM.
- **Linux**: ottenere privilegi root.

28.2.2 Recupero delle Credenziali

Una possibile strategia consiste nel recuperare credenziali o hash appartenenti ad altri utenti del sistema.

Le informazioni possono essere conservate in:

- database locali degli account;
- file di configurazione;
- repository di credenziali;
- meccanismi di autenticazione del sistema operativo.

28.2.3 Ricerca di Errate Configurazioni

La scalata dei privilegi può essere favorita dalla presenza di:

- file con permessi eccessivamente permissivi;
- servizi eseguiti con privilegi elevati;
- task schedulati configurati in modo errato;
- directory modificabili da utenti non privilegiati.

Particolare attenzione viene generalmente posta all'analisi:

- dei file di configurazione;
- degli script eseguiti automaticamente;
- delle pianificazioni periodiche del sistema.

28.3 Mantenimento dell'Accesso

Una volta compromesso il sistema, una problematica fondamentale consiste nel mantenere l'accesso ottenuto anche in seguito a riavvii o terminazione dei processi coinvolti.

28.3.1 Process Migration

Una tecnica comunemente studiata consiste nello spostare la sessione ottenuta verso processi più stabili e longevi.

Gli obiettivi principali sono:

- aumentare la stabilità della sessione;
- ridurre il rischio di perdita della connessione;
- garantire continuità operativa.

Tuttavia tali tecniche richiedono generalmente privilegi elevati e possono essere rilevate da strumenti di monitoraggio avanzati.

28.3.2 Tecniche di Persistenza

Per garantire la sopravvivenza dell'accesso nel tempo vengono studiati diversi meccanismi di avvio automatico.

Tra quelli maggiormente analizzati figurano:

- task schedulati;
- servizi di sistema;
- meccanismi di autorun;
- configurazioni di startup.

I meccanismi disponibili variano in funzione del sistema operativo utilizzato.

28.4 Data Collection

La raccolta delle informazioni rappresenta uno degli obiettivi principali della Post-Exploitation.

Le evidenze raccolte consentono di:

- valutare l'impatto reale della compromissione;
- dimostrare l'accesso a dati riservati;
- produrre evidenze da includere nel report finale.

Dal punto di vista aziendale, il valore della compromissione viene spesso misurato in termini economici, considerando il valore delle informazioni esposte o sottratte.

28.5 Internal Network Mapping

Una volta consolidato l'accesso su un host, questo può essere utilizzato come punto di osservazione privilegiato per analizzare la rete interna.

Le attività principali comprendono:

- identificazione delle interfacce di rete presenti;
- analisi della configurazione IP;
- studio delle tabelle di instradamento;
- identificazione degli host raggiungibili;
- analisi dei servizi disponibili nella rete interna.

Questa fase permette di ottenere una visione più completa dell'infrastruttura rispetto a quella disponibile dall'esterno.

28.6 Movimento Laterale

Le informazioni raccolte durante la mappatura della rete consentono di individuare nuovi sistemi potenzialmente vulnerabili.

L'attaccante può quindi:

- identificare ulteriori host;
- raccogliere nuove informazioni;
- verificare la presenza di vulnerabilità;
- estendere progressivamente l'accesso ad altri segmenti della rete.

Questo processo è comunemente definito **movimento laterale** (lateral movement).

28.7 La Natura Ciclica dell'Attacco

Una caratteristica fondamentale della Post-Exploitation è la sua natura iterativa.

Ogni volta che viene compromesso un nuovo sistema, il ciclo delle attività ricomincia:

$$\text{Network Scanning} \rightarrow \text{Banner Grabbing} \rightarrow \text{Enumeration} \rightarrow \text{Vulnerability Assessment} \rightarrow \text{Exploitation} \rightarrow \text{Post-Exploitation}$$

La ripetizione di questo processo consente di estendere progressivamente la conoscenza dell'infrastruttura e valutare il potenziale impatto di una compromissione su larga scala.

28.8 Obiettivi della Post-Exploitation

In sintesi, la Post-Exploitation ha lo scopo di:

- incrementare i privilegi ottenuti inizialmente;
- mantenere l'accesso nel tempo;
- raccogliere informazioni e prove della compromissione;
- esplorare la rete interna;
- valutare la possibilità di compromettere ulteriori sistemi.

I risultati ottenuti costituiscono la base tecnica necessaria per la stesura del report finale e per la definizione delle attività di remediation.

29 M12: The Final Report

Il report finale rappresenta il prodotto conclusivo di una campagna di penetration testing ed è il principale strumento di comunicazione tra il penetration tester e il cliente. La qualità del report è fondamentale, poiché anche un'attività tecnica eccellente può perdere valore se i risultati non vengono documentati in modo chiaro, replicabile e orientato al rischio.

29.1 Struttura Generale del Report

Il report deve fornire una descrizione chiara delle attività svolte e dei risultati ottenuti durante il penetration test.

Le sezioni principali comprendono:

- Executive Summary.
- Definizione dello Scope.
- Metodologia adottata.
- Risultati delle attività di testing.
- Vulnerabilità identificate.
- Piano di remediation.
- Conclusioni finali.

29.2 Executive Summary

L'Executive Summary è destinato principalmente al management e al personale non tecnico.

L'obiettivo di questa sezione consiste nel:

- fornire una panoramica dei rischi identificati;
- evidenziare le vulnerabilità più critiche;
- descrivere l'impatto potenziale sull'organizzazione;
- supportare il processo decisionale della dirigenza.

I contenuti devono essere sintetici, facilmente comprensibili e privi di dettagli tecnici eccessivamente complessi.

29.3 Definizione dello Scope

Una delle componenti fondamentali del report consiste nella definizione precisa dello scope dell'attività.

Devono essere chiaramente identificati:

- sistemi analizzati;
- indirizzi IP coinvolti;
- applicazioni testate;
- segmenti di rete inclusi;
- limitazioni operative eventualmente imposte dal cliente.

Una corretta definizione dello scope garantisce:

- trasparenza;
- replicabilità delle verifiche;
- corretta interpretazione dei risultati.

29.4 Descrizione delle Attività Svolte

Il report deve documentare cronologicamente tutte le fasi del penetration test.

Generalmente vengono riportate:

1. definizione dello scope;
2. information gathering;
3. network scanning;

4. enumeration;
5. vulnerability assessment;
6. exploitation;
7. post-exploitation;
8. eventuali attività di social engineering o phishing.

La documentazione dettagliata delle fasi consente di comprendere il percorso seguito durante l'analisi.

29.5 Metodologie e Standard di Riferimento

Per garantire coerenza e ripetibilità, è consigliabile fare riferimento a metodologie consolidate.

Tra i framework più utilizzati figurano:

- OWASP Web Security Testing Guide;
- checklist OWASP;
- standard e best practice del settore.

L'adozione di metodologie riconosciute consente di giustificare le scelte tecniche effettuate durante il test.

29.6 Valutazione del Rischio mediante CVSS

La gravità delle vulnerabilità viene normalmente classificata mediante il sistema **CVSS** (Common Vulnerability Scoring System).

Il punteggio tiene conto di diversi fattori, tra cui:

- vettore di attacco;
- complessità dell'attacco;
- privilegi richiesti;
- interazione dell'utente;
- impatto su riservatezza;
- impatto su integrità;
- impatto su disponibilità.

Le ultime tre metriche costituiscono la cosiddetta **CIA Triad**:

- Confidentiality;

- Integrity;
- Availability.

Il punteggio CVSS permette di assegnare una priorità oggettiva alle vulnerabilità rilevate.

29.7 Documentazione delle Vulnerabilità

Le vulnerabilità individuate devono essere elencate e ordinate in funzione del livello di rischio.

Per ciascuna vulnerabilità il report dovrebbe includere:

- descrizione dettagliata della vulnerabilità;
- analisi dell'impatto;
- livello di rischio;
- evidenze raccolte;
- procedura di verifica;
- raccomandazioni correttive.

29.8 Evidenze e Replicabilità

Uno degli aspetti più importanti del report consiste nel fornire prove tecniche che consentano di verificare i risultati ottenuti.

Le evidenze possono comprendere:

- screenshot;
- diagrammi;
- output di strumenti di analisi;
- log;
- Proof-of-Concept documentati.

Le informazioni raccolte devono permettere la ripetizione controllata delle verifiche effettuate.

29.9 Piano di Remediation

Per ogni vulnerabilità identificata deve essere definita una strategia di mitigazione o correzione.

Le contromisure possono essere suddivise in tre categorie principali.

29.9.1 Patch

La patch elimina direttamente la vulnerabilità alla radice.
Esempi tipici includono:

- aggiornamenti software;
- aggiornamenti del firmware;
- correzioni del codice sorgente.

29.9.2 Mitigation

La mitigation non rimuove il problema ma rende l'attacco più difficile o costoso.
Alcuni esempi comprendono:

- rafforzamento delle politiche di autenticazione;
- segmentazione della rete;
- restrizioni sugli accessi.

29.9.3 Workaround

Il workaround riduce gli effetti di un eventuale attacco senza eliminare la vulnerabilità.
Tra gli esempi più comuni figurano:

- backup periodici;
- sistemi di monitoraggio;
- regole IDS/IPS;
- procedure operative di emergenza.

29.10 Prioritizzazione degli Interventi

Sebbene il punteggio CVSS costituisca il principale riferimento per la priorità degli interventi, la pianificazione effettiva può dipendere da ulteriori fattori:

- criticità dei sistemi coinvolti;
- vincoli operativi;
- budget disponibile;
- impatto sui processi aziendali.

Di conseguenza, l'ordine degli interventi deve essere concordato con il cliente e adattato al contesto organizzativo.

29.11 Conclusioni

Il report finale rappresenta il risultato tangibile dell'intera attività di penetration testing. Esso non si limita a descrivere le vulnerabilità individuate, ma fornisce una valutazione strutturata del rischio, evidenze tecniche replicabili e un piano di remediation finalizzato all'hardening dell'infrastruttura.

Un report ben redatto costituisce quindi uno strumento essenziale per supportare il miglioramento continuo della sicurezza informatica e trasformare i risultati tecnici del test in decisioni operative concrete.